



UNIVERSITÀ DI PARMA

DIPARTIMENTO DI SCIENZE MATEMATICHE, FISICHE E INFORMATICHE
Corso di Laurea Triennale in Informatica

Open Source Intelligence nel Dark Web: Strumenti e Tecniche per la Protezione delle Infrastrutture Aziendali

*Open Source Intelligence on the Dark Web: Tools and
Techniques for Protecting Corporate Infrastructures*

CANDIDATO:
Emanuele Frimpong

RELATORE:
Prof. Roberto Alfieri

Indice

Introduzione	1
1 Il Dark Web	3
1.1 Struttura e Funzionamento	4
1.2 Concetti di base del Dark Web	6
1.3 Differenze tra Deep Web e Dark Web	7
1.4 Anonimato e Implicazioni di Sicurezza	10
2 L'OSINT	13
2.1 Definizione e Concetti Base dell'OSINT	14
2.2 Importanza e Applicazioni dell'OSINT	17
2.3 Tecniche e Strumenti di Raccolta Dati	19
2.4 Limiti e Sfide dell'OSINT	24
3 Implicazioni dell'OSINT nel Dark Web	26
3.1 Monitoraggio delle Minacce	27
3.2 Rilevazione dati	29
3.3 Vendita di Informazioni	30
3.4 Analisi di Comunità Online	32
3.5 Analisi delle Tendenze e Prevenzione	36
3.6 Minacce Emerse dal Dark Web	38
4 Tools e Tecnologie	40
4.1 OSINT Framework	41
4.1.1 Caratteristiche e Utilizzo	41
4.2 Maltego	42
4.2.1 Caratteristiche e Utilizzo	43
4.3 SpiderFoot	44
4.3.1 Caratteristiche e Utilizzo	44
4.4 Shodan	44
4.4.1 Caratteristiche e Utilizzo	45

4.5	Have I Been Pwned (HIBP):	46
4.5.1	Caratteristiche e Utilizzo	46
4.6	Altri strumenti utili:	47
5	Caso di Studio: Esempio Concreto	53
5.1	Obbiettivo	55
5.2	Preparazione dell'Ambiente di Lavoro	58
5.3	Raccolta di Dati tramite OSINT	60
5.4	Analisi delle Informazioni dal Dark Web	64
5.5	Risultati	69
6	Considerazioni Etiche e Legali	71
6.1	Normative sulla Privacy	72
6.1.1	Regolamentazioni Internazionali	73
6.2	Limiti Legali e Implicazioni Etiche	74
	Conclusione	76
	Bibliografia	78

Elenco delle figure

1.1	Livelli di Rete	4
1.2	Instradamento di tor (tre nodi)	5
1.3	Deep Web vs Dark Web	8
1.4	Utilizzo di Tor e le VPN per il traffico criptato	12
2.1	Processo generale di Open Source Intelligence	13
2.2	Attori OSINT	16
2.3	Active and Passive Open Source Intelligence	18
2.4	Social e Data Monitoring	20
2.5	Intelligenza Artificiale e Machine Learning	22
3.1	Dark Web Monitoring	29
3.2	Principali forum dal Dark Web	32
4.1	Tipologie di strumenti per la cybersecurity	40
4.2	OSINT Framework	42
4.3	Esempio di tracciamento con Maltego	43
4.4	Server con Remote Desktop Protocol esposto	45
4.5	Textbox di HIBP per la verifica di credenziali	46
5.1	Wayback Machine	55
5.2	Cyber Threat Intelligence Cycle	56
5.3	Infrastruttura ricreate in ambiente sandbox	58
5.4	Login di Darkowl	60
5.5	Landing page Darkowl	61
5.6	Risultato di una possibile ricerca	61
5.7	Rilevanza dell'output e hackishness	62
5.8	Installazione di Java	62
5.9	Transforms in Maltego	63
5.10	Transforms da utilizzare nel caso di una ricerca OSINT-Dark Web	63
5.11	Mappatura di esempio, dati universitari ed email personale	64

5.12	Landing page Splunk	65
5.13	Homepage Splunk	65
5.14	Ricerca generale di eventi	66
5.15	Metasploit	67
5.16	Ricerca di attacchi di tipo smb	67
5.17	Vulnerabilità Non Rilevata	68
5.18	Vulnerabilità Rilevata	68
6.1	La legge e la cybersecurity	73

Introduzione

Nell'odierno panorama della cybersecurity, l'evoluzione costante delle minacce digitali richiede un approccio proattivo alla protezione delle informazioni e degli asset aziendali. In particolare, il **Dark Web**, la parte più profonda e pericolosa del deep web, accessibile solo tramite strumenti specializzati come TOR, rappresenta un ambiente in cui vengono spesso scambiate informazioni sensibili e dati sottratti in modo illecito, che possono rappresentare un rischio significativo per le organizzazioni. La disponibilità di dati e informazioni sul Dark Web costituisce una risorsa preziosa per le operazioni di **OSINT**, che sfruttando fonti pubbliche e facilmente accessibili, permette di raccogliere informazioni e prevenire attacchi.

Il presente lavoro di tesi si inserisce in questo contesto, come strumento con l'obiettivo di esplorare l'integrazione delle informazioni del Dark Web come parte di una strategia di sicurezza aziendale, utilizzando risorse OSINT. Nello specifico, viene esaminato un caso di studio in cui una startup operante in ambito informatico e finanziario subisce un attacco. Questa minaccia porta alla compromissione delle credenziali, utilizzando strumenti di monitoraggio del Dark Web e di gestione dei log, viene dimostrato come un'organizzazione possa individuare le proprie vulnerabilità e adottare misure correttive e preventive.

Il contributo principale di questo elaborato risiede nella proposta di un approccio integrato che combina il Dark Web e l'uso di piattaforme OSINT, come soluzione per la gestione di incidenti e per rafforzare la sicurezza di un'azienda. Vengono inoltre esplorate le implicazioni pratiche all'adozione di tali strumenti, evidenziando come l'integrazione di diverse tecnologie possa migliorare la capacità di un'organizzazione di rilevare e rispondere alle minacce.

L'elaborato analizzerà come sia fondamentale mantenere una certa preparazione e prontezza contro le minacce emergenti, adottando un approccio in costante evoluzione e incentrato sulla sicurezza. Questo include il monitoraggio regolare del Dark Web, la formazione costante dei dipendenti (per

accrescere la consapevolezza sui rischi digitali) e l'aggiornamento delle policy di sicurezza. E verrà analizzata come l'integrazione di strumenti OSINT e di monitoraggio del Dark Web possano rappresentare un vantaggio competitivo significativo per le organizzazioni, aiutandole nella gestione dei rischi e nella protezione dei propri asset.

Capitolo 1

Il Dark Web

Parlando di Dark Web è fondamentale conoscere gli strati che compongono Internet.

”The Surface Web (Open Web or Clear Web in other synonyms) represents all websites that are publicly and easily accessible because search engines can index them. Alternatively, numerous websites are inaccessible because search engines cannot index them, forming the Deep Web (or the Invisible Web). In the latter, one needs to type the URL of the website directly in the address bar of the web browser, or the website itself is visible but its content needs a password to access it.” [7]

L’Open Web o il web di superficie rappresenta tutti quei siti web, pubblicamente e facilmente accessibili, siccome indicizzabili dai normali motori di ricerca. Esistono in oltre numerosi siti Web inaccessibili in quanto la loro indicizzazione non è possibile se non con l’utilizzo di browser e sistemi specifici, il loro insieme, forma il cosiddetto Deep Web (o Web invisibile).

Il Dark Web offre la possibilità di nascondere l’identità dell’utente, il traffico di rete e i dati scambiati al suo interno. Gli utenti esterni al Dark Web non possono accedervi utilizzando i normali browser web, ma solo tramite software speciali, come The Onion Router, anche conosciuto come TOR.



Figura 1.1: Livelli di Rete

Come possiamo vedere il web di superficie è solo la punta visibile al di sopra del livello dell'acqua. Sfortunatamente la maggior parte delle persone (aziende comprese) non competenti in ambito tecnologico o non a conoscenza di certi dettagli e informazioni, permettono l'indicizzazione dei propri dati. Ciò permette ad un'attaccante di raccogliere informazioni e ottenere l'accesso ai propri sistemi, a localizzare dati personali e molto altro.

1.1 Struttura e Funzionamento

Per poter accedere al dark web occorre utilizzare uno strumento in particolare: trattasi di Tor, The Onion Browser. Tor è stato progettato per assicurare una navigazione anonima sulle reti. Per accedere al dark web bisogna innanzitutto installare Tor Browser, utilizzabile esattamente come qualsiasi altro browser su sistemi quali Windows, Linux, macOS e device mobili. Il vantaggio di questo browser è la massima privacy garantita dalla navigazione in anonimato.

Navigare nel dark web non è semplice per l'utente medio: occorre prestare la massima attenzione per evitare di incappare nei pericoli che contraddistinguono questo livello sommerso di Internet. Prima di poter accedere a qualsiasi contenuto presente nel dark web, bisogna conoscere gli indirizzi giusti: senza di essi non è possibile navigare nel web oscuro.

Una volta installato Tor è possibile accedere al dark web, utilizzando motori di ricerca quali Onionland o DuckDuckGo.

Il dark web viene considerato un grande sottoinsieme del deep web. Esso contiene decine di migliaia di indirizzi URL. Ogni pagina si distingue per il

suo dominio .onion. Le pagine vengono ospitate da server che utilizzano i protocolli Tor.

Si stima che il dark web rappresenti solo il 5% della totalità di Internet. Questo universo nascosto risulta graficamente molto simile (seppur meno complesso ed esteticamente gradevole) al web superficiale e la navigazione è pressoché identica. La differenza sta nella struttura degli URL, che terminano con .onion piuttosto che con .com, .it o .eu.

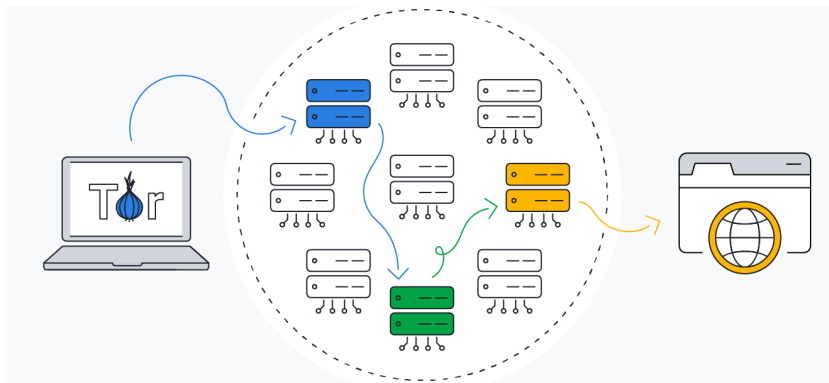


Figura 1.2: Instradamento di tor (tre nodi)

Uno dei metodi più utilizzati per accedere e navigare nel deep web è Tor. Questo network decentralizzato è costituito da server, i cosiddetti relay, dislocati in ogni angolo del mondo. Questi relay, ovvero i nodi, vengono gestiti da utenti specializzati e volontari. Si stima che i nodi Tor siano tra i 6.000 e gli 8.000. Mentre sono circa 3.000 i ponti (bridge) offerti da Tor.

I dati di navigazione, con Tor, non transitano dal client al server (come avviene durante una classica navigazione), ma i pacchetti di dati passano mediante i relay Tor che fungono da router. I relay realizzano un circuito virtuale crittografato a strati: una struttura a cipolla. Per questo, gli URL della rete Tor hanno un TLD (Top Level Domain) .onion, differente dal classico .com o .it.

Navigare sul deep web utilizzando Tor presuppone un processo particolare. Una volta aperto il browser Tor, sarà lo stesso browser a scegliere dall'elenco directory server la lista di nodi da utilizzare. La configurazione standard prevede tre nodi, scelti in modo casuale, i quali formano la catena di navigazione. Il circuito può essere consultato in tempo reale mediante la pagina del browser e può essere cambiato cliccando sul pulsante a sinistra della barra dell'URL.

La comunicazione viene crittografata a qualsiasi livello della catena di navigazione. La crittografia si ripete lungo tutti i nodi: i nodi possono conoscere solo il nodo immediatamente precedente e immediatamente successivo,

e nessuno degli altri. È quasi impossibile (o comunque molto complesso) risalire al client di partenza. È per questo che l'utente potrà navigare in anonimato.

Il traffico Tor passa per almeno tre relay prima di raggiungere la destinazione:

- Il guard relay, ovvero il nodo di guardia o di partenza;
- Il middle relay, ovvero il nodo intermedio che riceve il traffico e lo passa al relay successivo;
- L'exit relay, il nodo di uscita.

È poi fondamentale ricordare che il browser Tor non viene utilizzato solamente per navigare nel deep web e nel dark web (inaccessibile mediante i comuni motori di ricerca) ma anche per il surface web (in totale anonimato).

1.2 Concetti di base del Dark Web

Il dark web è quindi un contenitore di informazioni, basato sul web e caratterizzato da sistemi di comunicazioni anonimi, con lo scopo di proteggere utenti e la loro identità attraverso tecnologie, quali le comunicazioni criptate, la crittografia del traffico e il suo offuscamento. Grazie alla sua massiccia garanzia dell'anonimato, il dark web è diventata pian piano il canale principale per lo scambio e la distribuzione di contenuti pericolosi, vietati o illegali.

Il Dark Web è diventato il principale strumento per veicolare questi contenuti grazie appunto alle sue caratteristiche. Troviamo tra i suoi principali usi quello dei marketplace illeciti (per l'acquisto di droghe, armi, materiale pornografico illegale, carte di credito rubate e documenti) e quello del Cybercrime-as-a-Service, in quanto è possibile interagire con fornitori di servizi illegali. Questa nuova industria di servizi per i cybercriminali ha modificato notevolmente il panorama delle minacce per le aziende di tutte le dimensioni.

In particolare attacchi ransomware ¹, phishing, cryptojacking e attacchi di tipo distributed denial-of-service (DDOS) per conto di altri, dietro pagamento di una commissione.

Il potere distruttivo e accattivante degli attacchi ransomware è dato dal fatto che nella maggior parte dei casi il fornitore del servizio prende semplicemente una percentuale dei profitti. Ciò significa che chiunque può sfruttare a pieno questi attacchi debilitanti senza bisogno di competenze IT o investimenti finanziari.

I fornitori di Cybercrime-as-a-Service più sofisticati forniscono persino dashboard a cui i loro clienti possono accedere per monitorare il progresso e il tasso di successo della loro campagna di attacco.

1.3 Differenze tra Deep Web e Dark Web

Come detto in precedenza il web come lo conosciamo, comprende solo la parte indicizzabile e pubblicamente accessibile, consultabile tramite Google, Bing, Yahoo e altri motori di ricerca (Questo lato della rete contiene all'incirca 55 miliardi di pagine web).

Può sembrarci un numero davvero elevato, ma il numero di siti web presenti su internet non indicizzabili e non pubblicamente visibili è ancora più elevato, in questa parte della rete possono accedere solo governi, servizi militari e altre organizzazioni, ad esempio la NASA, questi servizi sono nascosti dal resto della società e l'insieme di questi contenuti forma il deep Web. Si stima che il deep web sia da 400 a 500 volte più grande del web di superficie. Il dark web di cui abbiamo parlato finora, fa parte del cosiddetto deep web e fornisce anonimato e sicurezza a chiunque la visiti, il dark web, viene utilizzato per molteplici scopi, sia legali che illegali. Ed è costruita su una serie di reti sovrapposte. ²

¹Programma informatico dannoso ("malevolo") che può "infettare" un dispositivo digitale, bloccando l'accesso a tutti o ad alcuni dei suoi contenuti, per poi chiedere un riscatto ("ransom").

²Queste reti prendono il nome di Overlay Networks

Deep Web vs. Dark Web	
Deep Web	Dark Web
 Can protect information stored online	 Makes your online activity anonymous
 Can access from anywhere with specific passwords or unique links	 Can only access with a dark web browser, similar to the Tor Project
 Makes up about 96% of the internet	 Size is unknown
 VPNs can help keep your IP address and identity safe	 Dark web browsers provide automatic encryption

Figura 1.3: Deep Web vs Dark Web

”So is there a difference between the invisible or deep web and Dark web?

Many people that know about the invisible web will give a different answer to this question because it is easy to consider them as being the same thing. Central to the Dark web discussion are key definitions to reduce the confusion concerning Deep web, Dark web and anonymous browsing. The Deep web is, in a sense, the content of databases and other services of the web that for one reason or another cannot be indexed by the typical search engines that everybody uses. The Deep web is not all bad. The Dark web on the other hand is part of the Deep web, and requires a specially designed browser and encryption methods to access. Neither the Deep nor Dark web can be indexed when seeking information which leads people to believe that they are the same. But the two categories of web that cannot be indexed are synonymous. The Dark web is a massive cyber underground world where some of the worst kinds of people like hackers, gangsters, terrorists, and pedophiles go to have fun or purchase anything. Some people might even consider the Dark web to be the black market where one can acquire things like drugs, counterfeit currency, forged documents, firearms and explosives,

human organs, and even hitmen. One cannot expect to purchase these things by inputting a credit card number and providing an address to which to have it shipped. There are certain things that help Internet crime work. Forms of cryptocurrency, such as bitcoins, facilitate currency exchange for whatever the purchaser wishes. Many organized cybercrime syndicates even have the ability to outsource hackers for hire. There are sites on the invisible web where one can contract certain “entities” to hire a hacker to do the dirty work for a well-funded organization or person. As explained, one can see there is a difference, whether it is slight or not, between the Deep and Dark web. Both require special access but one is far more dangerous than the other. The Dark web (or Dark Net) is a twisted and maniacal place where some of the world’s most unsavory or dangerous people or groups centralize to stay “under the radar” of government agencies or others that may condemn their actions.” [3]

Possiamo quindi affermare che il dark web sia la parte più pericolosa e profonda del deep web, un enorme mondo “sotterraneo” dove diversi criminali, come hacker, gangster, terroristi e pedofili, vanno per divertirsi o acquistare qualsiasi cosa. Il Dark web viene spesso considerato il mercato nero dove è possibile acquistare droghe, valuta contraffatta, documenti falsi, armi, esplosivi, organi e persino sicari. In questo ambiente vengono utilizzate criptovalute, come i bitcoin, per facilitare lo scambio.

Come spiegato, si può vedere come ci sia una differenza, sebbene minima o meno, tra deep web e dark web. Entrambi richiedono un accesso speciale, ma uno è molto più pericoloso dell’altro. Il dark web (o Dark Net) è un luogo perverso dove alcune delle persone o dei gruppi più pericolosi al mondo si centralizzano per rimanere “sotto il radar” delle forze dell’ordine.

La maggior parte dei contenuti del dark web può risultare estremamente inquietante, tuttavia esistono anche utilizzi rispettabili e legittimi di questa tecnologia.

Di seguito alcuni degli utilizzi legittimi:

- SecureDrop è un software open-source per la comunicazione sicura di informazioni, utilizzato dalle organizzazioni mediatiche per ricevere documenti da fonti anonime in modo sicuro. Viene utilizzato tramite la rete Tor e nel tempo questo e altri servizi simili sono stati impiegati dall’Associated Press, The Washington Post, The New York Times, CBC, ProPublica e molte altre organizzazioni.
- Giornalisti che risiedono in stati con regimi repressivi usano Tor per comunicare con il mondo esterno e per poter diffondere ingiustizie sociali e le violazioni dei diritti umani che avvengono in determinati periodi di crisi o conflitto.

- Tor permette ad agenti delle forze dell'ordine di navigare e visitare siti e servizi sospetti senza lasciare tracce compromettenti. Questo perchè nel caso in cui un indirizzo IP di un'agenzia governativa o delle forze dell'ordine fosse rilevato nei log del sito, rivelerebbe che il sito è sotto sorveglianza.
- Tor consente inoltre di eludere la censura statale. Un esempio significativo è rappresentato dal blocco dell'accesso a ProtonMail da parte della Turchia.³ In quella circostanza, l'unico modo per i residenti turchi di accedere al servizio di posta elettronica sicuro e criptato era tramite il sito .onion di ProtonMail. [4]

1.4 Anonimato e Implicazioni di Sicurezza

Ci sono diversi browser che vengono utilizzati per accedere al deep web, come già detto il più conosciuto è TOR browser. Tor (The Onion Router) è stato creato a metà degli anni 90 come risultato di un progetto condotto dall'US Naval Research Lab⁴, uno dei contributi più rilevanti del laboratorio è stato appunto lo sviluppo di Tor, una rete anonima progettata per proteggere la privacy degli utenti su Internet e con l'obiettivo di garantire comunicazioni sicure per il governo statunitense, in particolare per i militari, le forze dell'ordine e i diplomatici che operano in aree in cui la privacy è cruciale. Tor utilizza un sistema di "onion routing", dove il traffico dati viene crittografato in più strati e inoltrato attraverso una serie di nodi volontari in tutto il mondo, rendendo difficile il tracciamento dell'origine o della destinazione finale del traffico. Il progetto è diventato poi Open Source nel 2004.

Per garantire anonimato e sicurezza utilizza una serie di entry point randomici selezionati da una serie di server e le richieste vengono criptate e inoltrate insieme all'indirizzo di destinazione finale. Ogni nodo successivo decripta l'indirizzo e cripta nuovamente la richiesta per poi inoltrarla (ogni nodo conosce solamente il nodo precedente e quello successivo). Al termine le informazioni raggiungono l'exit point da dove poi vengono indirizzate verso la loro destinazione finale.

³Nel mese di giugno 2020, imposto dal governo come parte delle restrizioni sulle comunicazioni, in linea con la politica di controllo delle comunicazioni digitali e della libertà di espressione

⁴Organizzazione di ricerca scientifica e ingegneristica della Marina degli Stati Uniti

Inoltre, per garantire un livello di sicurezza maggiore i percorsi di instradamento vengono aggiornati approssimativamente ogni 10 minuti, per garantire maggior sicurezza nel caso in cui il traffico in corso sia monitorato. Hornet è una rete di onion routing ad alta velocità che sfrutta un'architettura di ultima generazione per rendere il tracking più complicato.⁵

Il funzionamento prevede l'attraversamento di diversi server creando passaggi virtuali, rendendo il tracciamento dell'IP un processo complesso. Ciò che rende Hornet più sicuro rispetto al browser TOR è che, quando Hornet è in uso, il sistema non memorizza gli stati delle sessioni, al contrario, Hornet trasferisce gli stati delle sessioni agli host finali per impostazione predefinita, criptando ogni pacchetto per ridurre il rischio di perdite di dati.

Recentemente è stato messo in discussione la protezione offerta dal browser TOR, in quanto nella realtà odierna esiste sempre almeno un individuo con competenze informatiche tali da poter violare qualsiasi rete su qualsiasi sistema, servendosi semplicemente di un dispositivo in grado di accedere alla rete e una connessione Internet.

"Una nuova ricerca del MIT (Massachusetts Institute of Technology) mostra come le entry guard "maligne" di TOR possano eliminare le funzionalità di anonimato del Dark Web, esponendo gli utenti e i siti web che visitano."

Il processo tramite la quale è possibile tracciare gli utenti di TOR è chiamato "website fingerprinting", quando un utente tenta di eseguire fingerprinting attack, deve iniziare con l'analizzare il comportamento di TOR e della rete formata (quindi, i nodi che compongono il collegamento) quando avviene una connessione. Durante la fase di costruzione del circuito per la comunicazione tra un client e un servizio nascosto, TOR presenta schemi di traffico unici che permettono ad un avversario di identificare e correlare in modo efficiente e accurato i nodi coinvolti nella comunicazione. Si andrà quindi a identificare i circuiti sospetti, per ridurre lo spazio di indagine ai soli servizi nascosti.

Un altro modo per tracciare un'utente è quello di monitorare i suoi keystroke, proprio come la grafia di ognuno è differente, anche quando si utilizza un computer è possibile differenziare un modello di keystroke dall'altro.

Il modo migliore per non essere tracciati è quello di avere un basso profilo e restare alla larga da attività illegali, in quanto nulla è davvero anonimo.

⁵Hornet viene sviluppato da Chen Chen, del Carnegie Mellon University assieme a Daniele Enrico Asoni, David Barrera, George Danezis and Adrian Perrig

Altri suggerimenti per rimanere il più anonimo possibile consistono nel:

Usare metodo di pagamento specifici, in particolar modo criptovalute, quali Bitcoin (BTC) e Monero, questo perchè sono le monete più facili da ottenere e scambiare, e perchè Monero può essere acquisto solo utilizzando un'altra criptovaluta.

E l'utilizzo di una Virtual Private Network (VPN) prima di accedere al browser. Questo andrà a mascherare l'indirizzo IP dell'utente aggiungendo un ulteriore livello di sicurezza e anonimato.

Sarà poi necessario individuare gli URL .onion di interesse, tramite specifiche directory e forum sul dark web, lasciando il minor numero di tracce possibili.

É fondamentale non scaricare file sconosciuti o fare clic su annunci, in quanto queste semplici azioni potrebbero dare il via ad una serie di attacchi informatici, con download falsi e potenzialmente infettati da diversi malware e virus.



Figura 1.4: Utilizzo di Tor e le VPN per il traffico criptato

É fortemente consigliato il collegamento ai soli siti HTTPS. In cui i dati vengono trasmessi in forma crittografata, tramite l'utilizzo di un certificato SSL. TOR non utilizza lo stesso certificato ma questa precauzione è da considerare sul web di superficie.

É fondamentale non rivelare mai informazioni personali quali nome, indirizzo, numero di telefono, email e profili sui social media.

In fine l'utilizzo di software Antivirus.

Capitolo 2

L'OSINT

L'open source intelligence (OSINT) è il processo di raccolta e analisi delle informazioni pubblicamente disponibili sulla rete, questi dati vengono poi utilizzati per valutare le minacce, prendere decisioni o rispondere a domande specifiche.

L'OSINT è generalmente definito come una qualsiasi azione di intelligence eseguita con l'utilizzo di informazioni pubblicamente consultabili (Open Source)¹, che sia raccolto, ordinato e diffuso in modo tempestivo allo scopo di rispondere a requisiti specifici.



Figura 2.1: Processo generale di Open Source Intelligence

¹Giornali, riviste, TV, radio, report commerciali, social media, siti e forum

Questo tipo di dati assume connotazioni differenti a seconda di chi le utilizza, alcuni esempi:

- Per la CIA, può significare informazioni ottenute da trasmissioni di notizie straniere.
- Per un avvocato, può significare dati ottenuti da documenti governativi pubblicamente disponibili.
- E per la maggior parte delle persone, può significare la moltitudine di contenuti ottenibili da Internet.

Durante un'operazione di OSINT è consigliabile effettuare una serie di operazioni allo scopo di tutelarsi, partendo da un buon antivirus, siccome è fondamentale essere in possesso di un primo livello di protezione, nel caso in cui i dati consultati non fossero sicuri o eventuali informazioni scaricate contenessero dei virus.

Da notare che i normali antivirus sono in grado di proteggere il dispositivo, nel solo caso in cui il virus sia già conosciuto e categorizzato (non proteggono da ogni minaccia). Generalmente il programma preinstallato windows defender può essere sufficiente come barriera contro la maggior parte delle minacce conosciute.

È consigliabile inoltre che, se il sistema utilizzato sia Windows o Mac, sia predisposto un ulteriore livello di protezione da file dannosi, **Malware**, uno dei software più utilizzati a questo scopo è "Malwarebytes", software che permette la pulizia e la protezione del dispositivo da diversi tipi di minaccia malware.

Un altro consiglio per chiunque navighi "in profondità" sul web, è quello di utilizzare un web browser con più livelli di sicurezza e possibilità di plugin e estensioni, quali Firefox o Chrome.

2.1 Definizione e Concetti Base dell'OSINT

Come definito in precedenza l'Open Source Intelligence si riferisce alla raccolta, all'analisi e all'utilizzo di informazioni provenienti da fonti di informazione pubblicamente accessibili.

I dati raccolti vengono elaborati e analizzati per estrarre da essi, informazioni significative. L'analisi delle informazioni dovrà includere l'eventuale correlazione di dati da fonti multiple, l'identificazione di schemi e tendenze, e la verifica dell'autenticità di queste ultime.

Esistono diversi strumenti e framework per eseguire attività di OSINT, come Maltego, The OSINT Framework, Shodan e molti altri.

Le principali aree di utilizzo delle tecniche elencate sono:

- Sicurezza Nazionale
- Cybersecurity
- Indagini Forensi e Criminali
- Protezione della Reputazione e dell'immagine
- Business Intelligence
- Stalking

Si ricorda che durante ogni operazione di raccolta dati è fondamentale rispettare la privacy, ed in particolare le normative sulla protezione dei dati (come il GDPR in Europa) e ogni altra legge locale e internazionale.

È indispensabile poi sottolineare che non tutte le informazioni disponibili pubblicamente sono accurate o affidabili; è necessario infatti un processo rigoroso di verifica e validazione. Il volume dei Dati, potrebbe presentarsi come un'ulteriore sfida, siccome la gestione di un'enorme quantità di dati provenienti da diverse fonti può essere complessa e neccessità di essere eseguita in modo rigoroso, con l'analisi del contesto².

Con l'evoluzione di Internet e la crescita delle piattaforme digitali, l'O-SINT continua ad espandersi, sfruttando anche l'intelligenza artificiale e il machine learning per migliorare l'analisi dei dati e la previsione delle minacce.

²Comprendere il contesto delle informazioni raccolte è fondamentale per evitare interpretazioni errate.

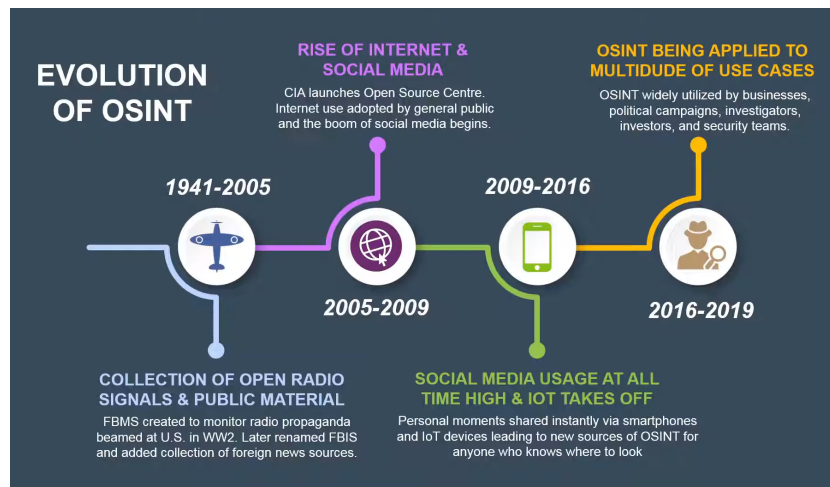


Figura 2.2: Attori OSINT

La Storia dell'OSINT è riconducibile agli albori della Seconda guerra mondiale, con l'istituzione del BBC Monitoring Service nel Regno Unito, 1939, e del Foreign Broadcast Monitoring Service (FBMS) negli Stati Uniti, 1941. Sebbene questi due servizi siano stati istituiti in risposta all'avvento della radiofonia e siano certamente esempi dei primi sforzi strutturali per raccogliere e sfruttare informazioni pubblicamente disponibili, è certo che l'OSINT abbia una storia istituzionale molto più lunga.

L'Open Source Intelligence ha ricevuto un'attenzione crescente negli ultimi decenni, in particolare con l'avvento dell'era dell'informazione e con l'ascesa di internet, grazie inoltre ai domini digitali per la produzione e l'archiviazione dei dati è avvenuto un cambiamento radicale per tutte le comunità d'Intelligence.

Il primo utilizzo pubblico della frase "open-source intelligence" e dell'acronimo "OSINT" nella letteratura sugli studi sull'intelligence risale ad un articolo del 1990 di Robert Steele ³

³Robert David Steele (1952 – 2021) American case officer for the Central Intelligence Agency, co-founder of the United States Marine Corps Intelligence Activity

Sebbene la raccolta e lo sfruttamento di dati da fonti pubblicamente accessibili non avesse guadagnato importanza fino a questo momento, l'utilità dei dati da fonti pubbliche risale a molto tempo prima. Per esempio l'uso pratico delle fonti aperte durante la Seconda Guerra Mondiale, documentate da diverse pubblicazioni risalenti al 1946, da William Donovan. Tuttavia, ci volle fino agli anni '90 prima che l'acronimo "OSINT" iniziasse a essere utilizzato e ci vollero altri due decenni prima che quell'uso diventasse diffuso nella letteratura sugli studi sull'intelligence.

Viene sostenuto da diversi autori che ciò che oggi chiamiamo OSINT, esisteva ed era già presente millenni fa, questo siccome dai legionari romani, ai vichinghi, ai mercanti della Via della Seta, venivano conservate e ricercate informazioni, osservando il mondo circostante, allo scopo di poter poi comprendere e diffondere le conoscenze ad altri. Da notare però che "non è stato un sforzo metodico fino a quando gli Stati Uniti non hanno fatto da pionieri nell'istituzionalizzazione e professionalizzazione di una capacità autonoma di monitoraggio dei media stranieri, con l'istituzione del **Foreign Broadcast Monitoring Service**" [2].

2.2 Importanza e Applicazioni dell'OSINT

I risultati possono essere utilizzati per individuare fughe non autorizzate di dati proprietari o sensibili, valutare la sicurezza delle informazioni e identificare vulnerabilità come software senza patch, configurazioni errate o porte aperte. Le organizzazioni possono anche condurre test di penetrazione dei propri sistemi e reti utilizzando gli stessi dati OSINT accessibili al pubblico da criminali informatici e hacker.

Spesso, le informazioni raccolte durante una valutazione OSINT vengono combinate con dati non pubblici per creare un report di threat intelligence più completo. Gli aggiornamenti di OSINT sulla cybersecurity possono aiutare le organizzazioni a mitigare il rischio di violazioni dei dati, ransomware, malware e altri attacchi informatici.[8]

L'Open Source Intelligence può essere sia attiva che passiva. Quello passivo comprende la raccolta e l'analisi dei dati, senza interagire direttamente con essi o con la loro sorgente. Per esempio un'intelligence di questo tipo può essere la ricerca e la raccolta di dati online da siti, social media e database pubblici, immagini satellitari e mappe. Rientra in questa tipologia anche la consultazione di documenti pubblici, report e articoli.

Quello attivo riguarda invece tutte quelle tecniche o operazioni che necessitano di un'interazione con la fonte, con gruppi o con utenti finali, i quali andranno a fornire i dati richiesti. Alcuni esempi sono, prendere parte ad

CAPITOLO 2. L'OSINT

un forum online, ad una discussion board o a diverse community presenti sui social riguardo ad uno specifico argomento.

Condurre colloqui, interviste o sondaggi e raccogliere informazioni da singoli o esperti di un determinato settore. Fanno parte di questa tipologia di dati, quelli raccolti prendendo parte a conferenze, osservando ed interagendo con il pubblico presente.

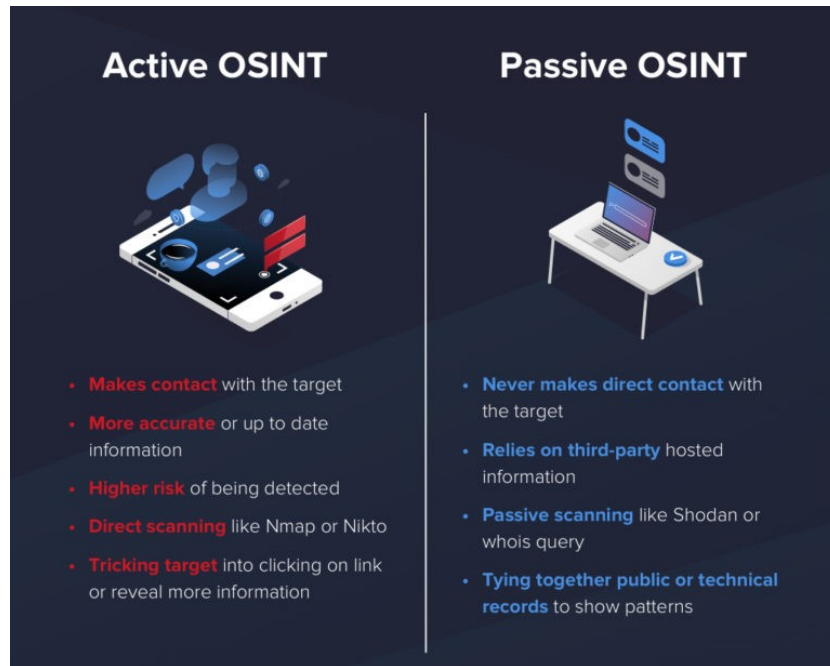


Figura 2.3: Active and Passive Open Source Intelligence

2.3 Tecniche e Strumenti di Raccolta Dati

Secondo Neotas⁴ e IBM⁵ esistono diverse tecniche e strumenti per condurre attività di intelligence:

1. Per il Web Data Scraping:

- (a) Advanced Scraping Frameworks: Strumenti come Scrapy (Python) e Apify mettono a disposizione capacità di scraping⁶ molto avanzate, incluso il trattamento di contenuti renderizzati tramite JavaScript, rotating proxies e scalando le operazioni di scraping su più macchine.
- (b) Headless Browsing: Sono browser senza interfaccia come Puppeteer (Node.js) e Selenium, i quali permettono uno scraping dinamico e AJAX (abbreviazione di Asynchronous JavaScript and XML) che permettono al programma di interagire con la pagina web, come fosse un'utente reale.
- (c) Estrazione e Parsing dei dati: Utilizzo di tecniche avanzate con l'impiego di modelli di machine learning per un'estrazione intelligente, come il naming entity recognition (NER) e l'optical character recognition (OCR) per l'estrazione di testo da immagini e PDFs.

2. Social Media Intelligence (SOCMINT):

- (a) Tecniche avanzate di monitoring dei Social Media: Strumenti quali Brandwatch, Crimson Hexagon, and Synthesio permettono un monitoring globale su più social media, fornendo analisi, riconoscimento di trend e utenti di rilievo.
- (b) Analisi dei Network: Strumenti per l'analisi della rete come Gephi and NodeXL possono essere utilizzate per visualizzare e analizzare social networks, identificare influencers, scoprire communities, e scoprire legami nascosti tra utenti e gruppi.

⁴Azienda specializzata nell'Open Source Intelligence, analisi dati, Intelligenza Artificiale (AI), che mette a disposizione diversi servizi all'avanguardia, background checks e Risk assessment, allo scopo di aiutare diverse aziende a prendere decisioni informate e a gestire i rischi in modo efficace.

⁵"Big Blue", è un'azienda statunitense del settore informatico, tra le più importanti al mondo. Produce e commercializza hardware, software e servizi informatici, offrendo infrastrutture, servizi di hosting, cloud, intelligenza artificiale, computazione quantistica e consulenza

⁶tecnica informatica di estrazione di dati da un sito web

- (c) Natural Language Processing (NLP): Le NLP sono tecniche, quali la modellazione dei dati, l'analisi dei sentimenti e il riconoscimento di entità possono essere applicati ai social media, per poter estrarre informazioni preziose, scoprire nuove tendenze e identificare potenziali rischi e minacce.

3. Dark Web Monitoring:

- (a) Crawlers e Scrapers automatici: Strumenti che come la libreria del progetto Tor e Scrapy-Splash Permettono il crawling e lo scraping automatico dei contenuti presenti sul dark web, permettendo la raccolta di dati su vasta scala.
- (b) Ambienti virtuali e Sandboxing⁷: Macchine virtuali, containers, e sandboxing sono spesso utilizzate per accedere e analizzare in modo sicuro, materiale proveniente dal dark web, isolando il sistema da potenziali minacce e mantenendo il sistema in sicurezza.
- (c) Monitoring di transazioni di Cryptovalute: I tool per l'analisi del Blockchain come Chainalysis and Elliptic permettono di monitorare e tracciare le transazioni che avvengono con le cryptovalute, potenzialmente scoprire transazioni illecite e attività sul dark web.



Figura 2.4: Social e Data Monitoring

⁷Ambiente sicuro e isolato su una rete, il quale imita gli ambienti operativi reali/finali

4. Intelligence Geospaziale (GEOINT):

- (a) Telerilevamento e Analisi di Immagini Satellitari: Tecniche più avanzate comprendono l'uso di dati di telerilevamento provenienti da fonti quali, Landset, Sentinel e fornitori commerciali uniti ad algoritmi di machine learning e rilevamento di oggetti, cambiamenti e pattern recognition.
- (b) Modellazione e visualizzazione 3D: Tools come ArcGIS Pro e ENVI possono essere utilizzati per creare modelli 3D di aree geografiche, per l'analisi dei dettagli di un territorio, per le infrastrutture e per diverse attività.
- (c) Integrazione dei dati geospaziali: L'integrazione di vari dati geospaziali, come immagini satellitari, fotografie aeree e dati GIS, possono fornire numerosi dati per un'area di interesse.

5. Analisi del Traffico di Rete:

- (a) Deep Packet Inspection (DPI): Le tecniche DPI comportano l'ispezione dei dati contenuti nei pacchetti di rete, consentendo un'analisi dettagliata del traffico di rete, la rilevazione di attività sospette o l'estrazione del traffico crittografato.
- (b) Network Behavior Analysis: Strumenti quali Zeek (conosciuto anche come Bro) e Suricata possono essere utilizzate per l'analisi dei pattern del traffico di rete, individuare anomalie e scoprire potenziali minacce.
- (c) Network Flow Analysis: Strumenti di analisi del flusso di rete come SiLK e Argus possono essere utilizzati per l'analisi dei flussi di rete, fornendo informazioni sui pattern di comunicazione, sull'utilizzo della banda di rete e potenziali incidenti di sicurezza.

6. Informatica Forense:

- (a) Memory Forensics: Strumenti quali Volatility and Rekall possono essere utilizzati per analizzare ed estrarre i dati da system memory dump di sistemi, consentendo il recupero di dati crittografati, file eliminati e numerose risorse forensi.
- (b) Disk and File System Forensics: Sono tecniche avanzate, che prevedono l'utilizzo di strumenti come The Sleuth Kit, EnCase, e FTK per eseguire un'analisi approfondita delle immagini del disco e del file system, per recuperare dati cancellati e per l'analisi di metadati e prove digitali.

- (c) **Malware Analysis:** Strumenti di sandboxing come Cuckoo Sandbox e Joe Sandbox possono essere utilizzati per l'analisi dinamica di Malware, consentendo l'esecuzione controllata e il monitoraggio di codice potenzialmente dannoso, per poterne capire il funzionamento.

7. Machine Learning e Intelligenza Artificiale:

- (a) **Natural Language Processing (NLP):** Le NLP sono tecniche, come detto, quali la modellazione dei dati, l'analisi dei sentimenti e il riconoscimento di entità possono essere applicati ai social media, possono essere utilizzate anche su grandi database, allo scopo di estrarre informazioni.
- (b) **Computer Vision e Image Recognition:** I modelli del Machine learning possono essere allenati per l'analisi e la classificazione di immagini, oggetti, e per l'identificazione di pattern.
- (c) **Predictive Analytics e Rilevamento anomalie:** Tecniche quali il clustering, e il rilevamento delle anomalie possono essere utilizzate per l'identificazione di pattern, prevedere eventi futuri e rilevare minacce all'interno di grandi insiemi di dati.

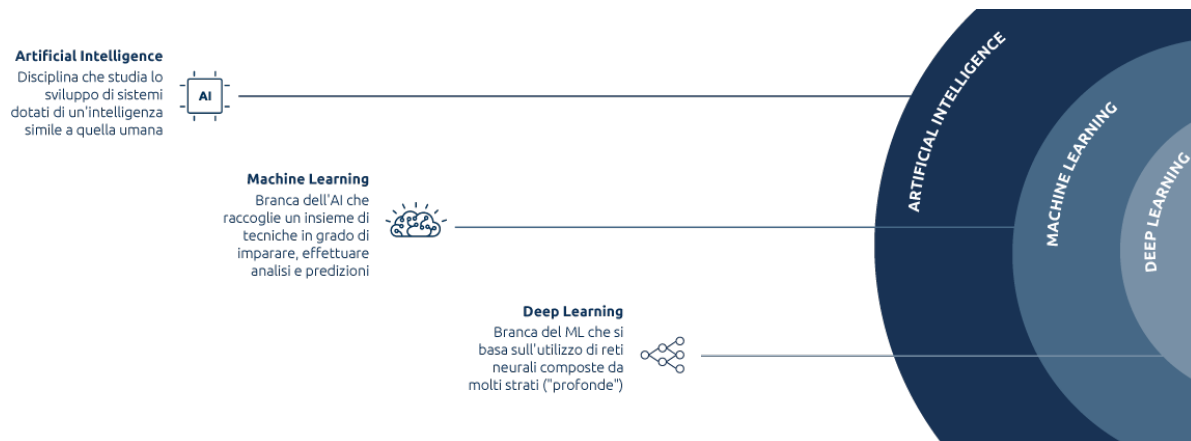


Figura 2.5: Intelligenza Artificiale e Machine Learning

8. Data Visualisation e Link Analysis:

- (a) Visualizzazione interattiva dei Dati: Strumenti quali Tableau, Power BI, e D3.js permettono la creazione di visualizzazioni interattive e dinamiche, consentendo agli analisti di esplorare e presentare i dati in modo intuitivo e leggibile.
- (b) Analisi di link e Visualizzazione Grafici: Strumenti come Neo4j, Gephi, e Palantir permettono l'analisi dei collegamenti e la visualizzazione di grafici, aiutando gli analisti ad individuare in modo più rapido e preciso, connessioni nascoste e comprendere relazioni complesse tra i dati.
- (c) Visualizzazione dei dati Geospaziali: Software GIS⁸ come ArcGIS e QGIS possono essere usati per visualizzare e analizzare dati geospaziali, consentendo la creazione di mappe interattive, unendo diversi dati e diverse risorse, per l'identificazione di trend e pattern.

Queste tecniche avanzate di OSINT spesso richiedono competenze particolari, oltre a una profonda comprensione dell'analisi dei dati e della programmazione. Sono tipicamente impiegate da agenzie di intelligence, forze dell'ordine, professionisti della sicurezza informatica e ricercatori per raccogliere informazioni, scoprire minacce e ottenere una visione completa di situazioni o fenomeni complessi.

Al giorno d'oggi, quasi tutti possono partecipare alla raccolta di open source intelligence, alcune delle fonti pubbliche da cui chi utilizza l'OSINT può raccogliere dati includono: Motori di ricerca internet come Google, DuckDuckGo, Yahoo, Bing e Yandex, mezzi di informazione cartacei e online, come giornali, riviste e siti di notizie, social network quali Facebook, Twitter(X), Instagram e LinkedIn, forum online e blog, il dark web, un'area crittografata di internet non indicizzata dai motori di ricerca, elenchi online di numeri di telefono, indirizzi e-mail e indirizzi fisici, registri pubblici di nascite, decessi, atti giudiziari e documenti aziendali, documenti governativi come trascrizioni delle riunioni, bilanci, discorsi e comunicati stampa emessi dai governi locali, statali e federali/nazionali, ricerche accademiche, inclusi documenti, tesi e riviste, dati tecnici quali indirizzi IP, API, porte aperte e metadati delle pagine web.

⁸Un sistema informativo in grado di associare dei dati alla loro posizione geografica sulla superficie terrestre e di elaborarli per estrarne informazioni

L'OSINT Framework è un insieme completo di processi, tecniche e strumenti progettati per facilitare la raccolta, l'elaborazione, l'analisi e la diffusione di informazioni ottenute da fonti open e pubbliche. Comprende numerose fonti di dati, tra cui siti web, social media, registri pubblici, notizie, pubblicazioni accademiche e altri materiali.

2.4 Limiti e Sfide dell'OSINT

Le considerazioni etiche sono fondamentali nel campo della raccolta di OSINT. È fondamentale aderire a standard legali come il Regolamento Generale sulla Protezione dei Dati (GDPR) e garantire la raccolta etica dei dati. Rispettare i termini di servizio, mantenere la trasparenza e salvaguardare la privacy individuale, che devono essere sempre rispettati durante tutto il processo di OSINT.

Durante l'uso di una qualsiasi tecnica di OSINT è fondamentale tener conto di alcuni ostacoli:

1. Information overload: L'enorme volume di dati pubblicamente disponibili, in quanto queste informazioni, provengono da varie fonti online e può risultare una mole travolgente di informazioni, e può rendendo difficile identificare informazioni rilevanti e affidabili.
2. Verifying source credibility: In quanto è indispensabile valutare la credibilità e l'affidabilità delle fonti di informazioni raccolte, poiché le fonti aperte possono contenere inesattezze, bias o disinformazione.
3. Legal and ethical constraints: I professionisti dell'OSINT devono navigare tra i confini legali ed etici, rispettare la privacy e i diritti di proprietà intellettuale, e aderire alle normative e politiche pertinenti.
4. Rapidly evolving data landscapes: Siccome l'evoluzione costante delle piattaforme online, dei formati dei dati e delle tecnologie richiede un adattamento continuo e lo sviluppo di nuove tecniche e strumenti OSINT.

A questo punto una domanda sorge spontanea, l'OSINT è legale?

L'OSINT è generalmente considerato legale in quanto implica la raccolta e l'analisi di informazioni provenienti da fonti pubblicamente disponibili. Tuttavia, è fondamentale seguire le linee guida, per quanto concerne la legalità e l'eticità, rispettare i diritti di proprietà intellettuale e evitare qualsiasi

accesso non autorizzato o pratiche di raccolta dati illegali. Le considerazioni etiche, come la protezione della privacy e la trasparenza, sono anch'esse essenziali quando si conducono attività di OSINT.

I tre pilastri dell'OSINT sono:

- I Conformità Legale ed Etica: Garantire che le attività di OSINT siano conformi alle leggi, regolamenti e standard etici, rispettando la privacy e i diritti di proprietà intellettuale.
- II Trasparenza: Promuovere la trasparenza nei processi di OSINT, nelle metodologie e nell'uso dei dati pubblicamente disponibili, favorendo la fiducia e la responsabilità.
- III Adattabilità: Adattarsi ai dati in continua evoluzione, incorporando nuovi strumenti, tecniche e metodologie per rimanere aggiornati ed efficaci di fronte ai progressi tecnologici e ai cambiamenti negli ambienti.

L'Open Source Intelligence ha però un lato oscuro, il quale si riferisce al potenziale uso improprio delle tecniche e degli strumenti di intelligence da fonti aperte per scopi illegali, non etici o dannosi.

Questi usi illeciti possono essere, la raccolta di informazioni per attacchi informatici, condurre sorveglianza non autorizzata o violare i diritti alla privacy, spionaggio aziendale, il furto di segreti commerciali, violazione di proprietà intellettuale, diffondere disinformazione, propaganda, fake news ed infine impegnarsi in pratiche di raccolta dati non etiche o illegali, come lo scraping senza autorizzazione o la violazione dei termini di servizio.

Capitolo 3

Implicazioni dell'OSINT nel Dark Web

Mentre il dark web presenta sfide e rischi unici, rimane una fonte essenziale di intelligence per le indagini OSINT, consentendo agli analisti di scoprire minacce nascoste, tracciare attività criminali e migliorare la consapevolezza in un panorama digitale sempre più complesso.

Vediamo ora come questi due strumenti possono interagire, allo scopo di raccogliere e elaborare il maggior numero di dati.

Il dark web svolge un ruolo significativo per quanto riguarda le investigazioni di Open Source Intelligence (OSINT), e sempre considerando la sua complessità e i rischi intrinseci. Vediamo alcuni punti chiave che evidenziano l'importanza del dark web per l'OSINT:

Accesso a informazioni nascoste: Il dark web contiene molti dati non indicizzati sui motori di ricerca tradizionali. Ciò include forum, marketplace e altre piattaforme dove diversi utenti prendono parte in attività illecite, come la vendita di dati rubati, droghe, armi e altro. Gli analisti OSINT possono accedere a queste informazioni per raccogliere dati non presente sui canali o sui browser convenzionali.

Monitoraggio di Attività Criminali: Le forze dell'ordine e gli analisti di cybersecurity monitorano frequentemente il dark web per tracciare attività criminali, tra cui attacchi informatici, frodi e terrorismo. Infiltrandosi in forum e mercati del dark web, gli investigatori possono raccogliere informazioni su potenziali minacce e reti criminali, aiutando nella prevenzione e per sventare attività illegali.

Identificazione delle minacce: Gli analisti OSINT utilizzano il dark web per identificare e profilare gli utenti che cercano di portare a termine diversi crimini, inclusi hacker, criminali informatici e gruppi estremisti. Monitorando i canali di comunicazione e osservando le interazioni tra di essi, gli

analisti possono scoprire informazioni preziose su questi individui o gruppi, come le loro tattiche e tecniche.

Monitoraggio dei Data Breaches: Il dark web è un punto caldo per la vendita e lo scambio di dati rubati, tra cui informazioni personali, registri finanziari e credenziali. Le indagini OSINT possono prevedere il monitoraggio dei mercati presenti sul dark web per identificare violazioni dei dati e valutare l'impatto su individui e organizzazioni. Queste informazioni possono essere cruciali per l'incident response e limitare i rischi.

Ricerca e Analisi: Oltre alle attività criminali, il dark web offre un terreno fertile per la ricerca e l'analisi su vari temi, tra cui minacce alla sicurezza informatica, economie sotterranee e tendenze emergenti. Gli analisti OSINT utilizzano strumenti e tecniche per navigare in modo sicuro nel dark web ed estrarre informazioni preziose per definire strategie e per valutare le minacce.

Sfide e Rischi: Nonostante la sua utilità, condurre indagini OSINT sul dark web presenta sfide e rischi importanti. Navigare attraverso i servizi nascosti richiede infatti strumenti e competenze di alto livello, per mantenere l'anonimato e la sicurezza operativa è fondamentale evitare di essere rilevati dagli avversari. Inoltre, l'interazione con le comunità presenti sul dark web comporta considerazioni etiche e legali che devono essere gestite con attenzione.

3.1 Monitoraggio delle Minacce

Monitorare le minacce e i propri dati permette di tracciare minacce e informazioni personali sul Dark Web. Sorvegliando i forum, i mercati e i servizi di messaggistica del dark web, gli investigatori possono approfondire le tendenze relative al traffico di droga, ai crimini finanziari, al furto di identità, alla vendita di armi, alla tratta di esseri umani e altro ancora. Per verificare la validità degli indizi e dei dati rilevati è possibile utilizzare piattaforme del dark web per verificare o smentire informazioni provenienti dal web di superficie, migliorando la credibilità degli indizi investigativi. Infine per contrastare le Minacce Interne è necessario identificare casi di data breach e scambiati sul dark web, questo aiuta a combattere le minacce interne e a rafforzare le misure di sicurezza informatica.

Le minacce possono essere furti di credenziali bancarie, numero, email o altri dati personali (allo scopo di appropriarsi dell'identità di un altro utente) e altre informazioni personali e sensibili.

Le attività di monitoring sono essenziali per due motivi in particolare:

1. perché i data breach sono spesso silenziosi, ovvero le imprese non si rendono immediatamente conto di aver subito un attacco;
2. perché scoprire per tempo una fuga di dati permette di mitigare il danno ed evitare che si ripropongano situazioni analoghe in futuro.

Se a tutto ciò si aggiunge un costo medio di data breach superiore ai 4 milioni di dollari – come suggerisce l'ultimo report IBM sul tema – ci si rende conto non solo dell'importanza del dark web monitoring, ma anche della sua urgenza. Si traduce nell'attività di monitoraggio costante dei siti e delle piattaforme del dark web finalizzata a collezionare informazioni che dimostrino all'azienda di aver subito un data breach.

In questa prospettiva, i tool di monitoraggio del dark web, disponibili come soluzioni stand-alone, software open source o parte integrante di piattaforme di sicurezza, esplorano il dark web per creare database di informazioni che permettono alle aziende di individuare se sono state vittime di violazioni dati o meno.

Non esiste un'indicizzazione unica, affidabile e sicura (come Google, per intenderci) dei servizi del dark web, e oltretutto il crawling dei portali pubblici non è sufficiente; occorre quindi registrarsi, ed interagire fino a aver conquistato la fiducia dei gestori dei siti stessi, che talvolta sono board dedicate allo scambio di informazioni.[1]

Il mondo dei tool di dark web monitoring è estremamente ampio e dinamico. Realizzare da zero una soluzione dedicata è una strada difficilmente percorribile, perché oltre alle competenze specialistiche, è necessario l'accesso a fonti riservate e una conoscenza approfondita di piattaforme, siti, marketplace e dei canali. Alcuni tool per il monitoring quindi possono essere OnionScan, BlackWidow¹, il dark web monitoring di NordVPN e Brandefense per la ricerca di informazioni su data breach. Infine piattaforme di cyber threat intelligence come IntSights.

¹OnionScan, per ricercatori e investigatori che monitorano e tracciano i siti del Dark Web e BlackWidow un tool che parte da un sito target e ne effettua scansione e mappatura completa



Figura 3.1: Dark Web Monitoring

Da sottolineare inoltre che il monitoraggio regolare dei propri dati personali, conti di credito e delle transazioni con carte di debito può aiutare a rilevare rapidamente qualsiasi attività non autorizzata e ad agire per prevenire le frodi.

Un altro strumento molto utile è il Daily Dark Web, sito web, specializzato nell'analisi e nel reportage approfondito delle attività del dark web. La loro copertura include approfondimenti dettagliati dei forum di hacker, dei canali Telegram (su cui avvengono attività illecite) e aggiornamenti da gruppi di ransomware. Il loro approccio va oltre il semplice reportage; Negli ultimi anni, i loro investigatori sono stati in grado di ottenere interviste con noti hacker come USDoD e RansomedVC, offrendo uno sguardo nelle menti e nelle motivazioni che guidano queste figure.

3.2 Rilevazione dati

La rilevazione dei dati, tramite OSINT sul dark web, presenta principalmente 2 difficoltà:

Accessibilità Limitata: La mancanza di indicizzazione dei motori di ricerca e i frequenti cambiamenti di indirizzo del dark web pongono ostacoli alla ricerca e al tracciamento efficiente delle prove, che possono rapidamente scomparire.

Affidabilità delle Informazioni: Le informazioni provenienti dal dark web potrebbero non essere sempre affidabili o accurate, rendendo necessari processi di validazione e verifica accurati. Per mitigare questi rischi, l'investigatore deve utilizzare software specializzati come Tor, utilizzare VPN e aggiornare costantemente i loro strumenti. Inoltre, devono prestare la

massima attenzione per evitare di lasciare tracce digitali che potrebbero compromettere la loro identità e l'integrità delle loro indagini.

Per analizzare e interpretare correttamente i dati ottenuti è essenziale avere un approccio sistematico.

1. Si deve raccogliere e organizzare il dato in base al tipo, assicurandosi che questo avvenga legalmente e eticamente,
2. Verificare e confermare l'informazione, effettuando cross-referencing dei dati con quelli del web di superficie quando possibile,
3. Identificare Connessioni e Reti, analizzando profili utenti, conversazioni e transazioni, mappando le reti e individuando i protagonisti,
4. Analizzare i modelli di attacco, identificando tattiche e tecniche, analizzando modelli e metodologie di attacco, allo scopo di migliorare le strategie difensive,
5. Ricavare Intelligence Attuabile, sintetizzando i risultati, evidenziando informazioni chiave, tendenze e assicurare la tempestiva diffusione dell'intelligence,
6. E mantenere la sicurezza operativa, implementando misure rigorose per la gestione e la protezione dei dati, utilizzando software specifici e applicando procedure di audit adeguate.

Ritroviamo diverse tipologie di dati ricavabili dal Dark Web, di seguito quelli di rilievo:

Profili utenti

Conversazioni

Transazioni (Crypto)

Attività illecite (vendita di articoli illegali)

Denunce e altri dati

Annunci da Marketplace

Connessioni (tra utenti, gruppi e organizzazioni)

Dati sensibili (Password e informazioni personali)

3.3 Vendita di Informazioni

Agli investimenti in cyber security spesso viene data poca importanza all'interno dell'azienda, il più delle volte per questioni legate a un presunto

risparmio. Invece abbiamo visto, che proteggere il patrimonio informativo ed evitare fughe di notizie a causa di attacchi di social engineering dovrebbero essere tra i principali obbiettivi. Anche perché, tutti i dati sottratti a aziende passano inevitabilmente attraverso il mercato nero del Dark Web.

Chi si appropria dei dati, con ogni probabilità non ne sarà l'utilizzatore diretto, bensì verranno rivenduti nei canali underground della rete.

Funzionamento dei marketplace:

Troviamo all'interno di questi siti uno degli elementi più costosi e ricercati, il malware premium, che può arrivare a costare cinquemila dollari (per mille installazioni). Altri listing sui siti possono comprendere, dati di accesso ad account PayPal (spesso non funzionanti grazie all'autenticazione a due fattori), accessi Netflix o dettagli di carte di credito rubate.

Riscontriamo spesso diversi tipi di frode in questi marketplace, che possiamo indicare in tre macro categorie:

La prima è relativa alla classica truffa in cui un'utente paga per l'acquisto di un determinato bene che mai arriverà nelle proprie mani; La seconda riguarda il pagamento per l'acquisto di materiale, il quale non risulterà conforme alle fotografie, ad esempio nel caso di documenti falsi; La terza categoria, infine, riguarda la truffa in cui, viene pagata una cifra molto elevata, per articoli e dati che l'utente sarebbe stato in grado di reperire a prezzi più convenienti, sul web di superficie.

É consigliabile quindi non favorire e non prendere parte a queste tipologie di transazioni.

Tuttavia, è sorprendente notare come le guide alle frodi e all'hacking siano alcuni degli articoli più venduti.

Le guide pratiche sulle truffe che includono tutorial su come eseguire attività dannose risultano le più vendute per il cinquanta per cento, seguite dalle vendite di dati personali e data Breaches².

Inoltre, troviamo anche diversi account e credenziali non finanziari, che includono account per servizi come Amazon, PayPal, Stripe, Kraken e altri media bancari e di cripto valuta.

Infine, ritroviamo strumenti e modelli di frode, i quali includono applicazioni che possono essere utilizzate come trojan³ e siti web preconfezionati per attacchi di tipo phishing.[9]

²comprendono nomi, numeri di telefono, indirizzi, indirizzi e-mail e codici fiscali

³Indica un tipo di malware, in cui come il cavallo dell'antica storia greca, si nasconde all'interno di un altro programma apparentemente utile e innocuo

3.4 Analisi di Comunità Online

I Marketplace più comuni, utilizzati per le investigazioni OSINT comprendono AlphaBay, Empire Market, e Silk Road (o i suoi successori, siccome successivamente a diverse operazioni delle forze dell'ordine e dell'FBI, molte di questi siti sono stati sequestrati e chiusi). Queste comunità facilitano lo scambio di beni e servizi illeciti, e forniscono informazioni preziose agli investigatori.

Oltre ai marketplace il Dark Web ospita una miriade di forum che operano al di fuori dei siti web convenzionali, fungendo da epicentri per attività di cybercriminalità. Questi forum non sono solo luoghi d'incontro per hacker e attori illeciti; sono ecosistemi dove dati rubati, strumenti di hacking e servizi illeciti vengono scambiati.

Qui ritroviamo forum come BreachForums e XSS, che offrono uno sguardo nel sofisticato mondo delle minacce informatiche e dei data breaches. Queste piattaforme, avvolte nell'anonimato, sono luoghi in cui i confini della legalità si confondono, mettendo alla prova gli sforzi di cybersicurezza a livello globale. Analizziamo le loro operazioni, i loro membri e l'impatto complessivo che hanno sia nel mondo cibernetico che in quello fisico.

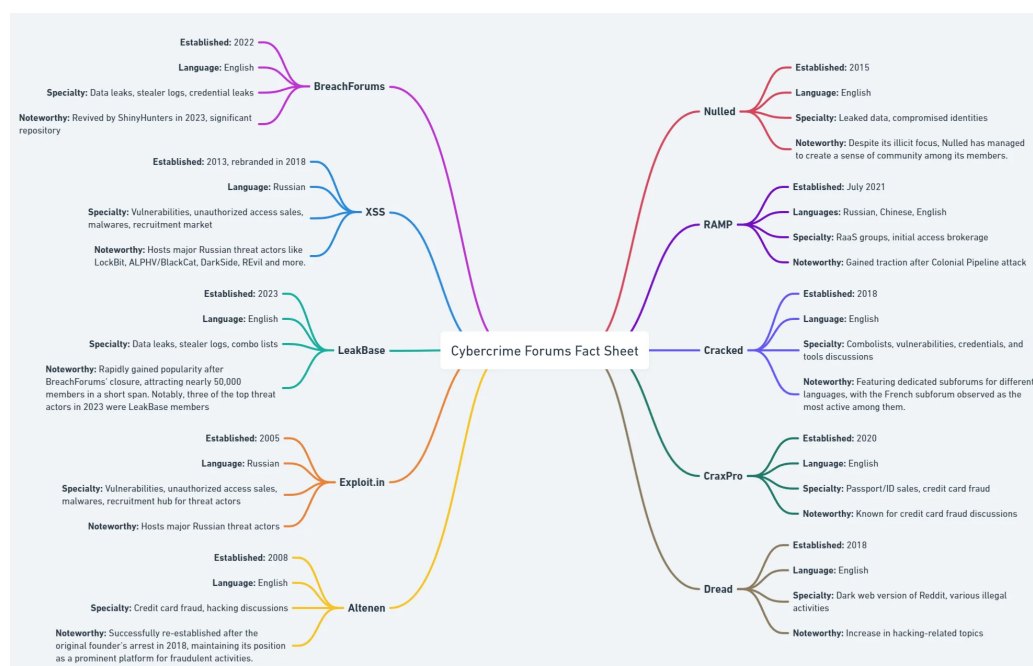


Figura 3.2: Principali forum dal Dark Web

Forum principali e come forum e come operano:

1. BreachForums:

BreachForums è emerso rapidamente come uno dei temi mainstream sui forum del dark web, specialmente dopo la chiusura di RaidForums e la sua sostituzione con quest'ultima. La storia iniziò quando un noto hacker, Pompompurin, lanciò Breached dopo la scomparsa di RaidForums.

Una sequenza di avvenimenti ha portato all'arresto di Pompompurin da parte delle forze dell'ordine statunitensi, il 15 marzo 2023, la chiusura di Breached (noto anche come BreachForums) non ha segnato la fine del forum. Al contrario, un nuovo team ha rilanciato il forum sotto il nome di BreachForums, diventando rapidamente il fulcro del dark web e riuscendo dove altri forum avevano fallito.

Il 12 giugno 2023, BreachForums ritorna sotto il nome di ShinyHunters, e si conferma come uno dei gruppi più attivi. Nonostante lo scetticismo iniziale sulla sua legittimità, con diversi utenti che temevano fosse una trappola dell'FBI, un messaggio firmato con PGP da un ex amministratore, Baphomet, ne conferma il ritorno. ShinyHunters, noto per significativi data breaches alle spese di aziende come Tokopedia e GitHub, ha continuato ad attirare l'attenzione per la vendita di dati rubati, evidenziando le costanti sfide in materia di cybersecurity e protezione dei dati.

BreachForums si distingue per i suoi database admin-approved, vantando oltre 15 miliardi di record provenienti da 936 dataset e una serie di sezioni particolarmente attive del forum, tra cui Leaks, Stealer Logs e il suo ranking system (VIP, MVP, GOD), insieme a un sistema di punti di credito, all'interno del forum e bastato sulle transazioni.

L'importanza del forum, tuttavia, deriva dalla da alcuni dei membri quali, i fondatori e hacker di rilievo.

2. XSS:

XSS, con una storia che risale al 2013, emerge non solo come uno dei forum più antichi ma anche come un importante hub per hacker competenti nel panorama cyber Russo. Fondato nel 2013, il forum ha subito un rebranding nel 2018, adottando il nome XSS in riferimento alla vulnerabilità Cross-Site Scripting dopo l'arresto di uno dei suoi amministratori nel 2017. Operando sia come piattaforma TOR sia accessibile dal web di superficie, XSS si presenta come un forum hacker dove le

discussioni ruotano principalmente attorno alla vendita di credenziali, malware, vulnerabilità di sicurezza e data breach.

Data la sua base di utenti Russi e la sua notorietà, XSS ha ospitato celebri hacker russi, tra cui LockBit, ALPHV/BlackCat, REvil e il gruppo DarkSide responsabili dell'attacco al Colonial Pipeline⁴. Il forum funge da punto di incontro, facilitando annunci di reclutamento e varie transazioni di malware, virus e altri strumenti. I gruppi di Ransomware-as-a-Service (RaaS) e altri hacker utilizzano XSS per scopi di pubbliche relazioni, partecipando a discussioni e promuovendo le loro attività allo scopo di rafforzare la loro reputazione.

3. **LeakBase:**

LeakBase emerge come uno dei forum più recenti e importanti di questa lista. Si stima sia stata creata nel gennaio 2023, questo forum in lingua inglese è accessibile sul web di superficie e ha rapidamente guadagnato popolarità, soprattutto dopo la chiusura di BreachForums nel marzo 2023. E ha colmato il vuoto creato nel panorama del cyber crime, guadagnandosi una certa notorietà.

Con un sistema di classificazione simili a BreachForums e il suo sistema di crediti, LeakBase ha attirato l'attenzione, guadagnando quasi 50.000 membri in breve tempo. Il forum evidenzia discussioni su data leaks, stealer logs, combo list, vulnerabilità, malware e persino software legali, ognuno contenuto in una categoria distinta.

Inoltre, il forum presenta una sezione privata dedicata a contenuti esclusivi ed è vietato condividere informazioni riguardo la Russia.

4. **Exploit.in:**

Fondato nel 2005, Exploit si presenta come uno dei principali forum hacker russi nel panorama del cyber crime, simile a XSS. Opera sia su TOR che sul web di superficie, Exploit serve come punto di ritrovo per data dump iniziali, facilitando la vendita di credenziali, la diffusione di malware, data breaches e le transazioni di database, sia per la loro vendita che per la loro distribuzione gratuita.

Proprio come XSS, Exploit sfrutta la sua capacità nel connettere i cybercriminali con potenziali collaboratori, allo scopo di organizzare attività di hacking, frode o per l'organizzazione di gruppi Ransomware-as-a-Service (RaaS).

⁴Un'importante attacco ransomware che prese di mira la Colonial Pipeline Company, il più grande operatore di gasdotti negli Stati Uniti, nel maggio 2021

Con la sua organizzazione strettamente strutturata e le sue politiche di adesione, Exploit proietta quasi un'aura di professionalità.

5. **Altenen:**

Altenen si distingue dagli altri forum in lingua inglese accessibili sul web di superficie. Focalizzandosi su una varietà di attività fraudolente, in particolare, frode con carte di credito, il forum approfondisce discussioni sulle diverse tecniche, (cracking, hacking, argomenti IT e molto altro).

Fondato nel 2008, Altenen ha affrontato una battuta d'arresto quando il suo fondatore è stato arrestato nel maggio 2018, ma grazie alla condivisione su social network come X e YouTube, la piattaforma ha continuato ad avere una fanbase molto attiva.

6. **Nulled:**

Fondato nel 2015, Nulled è un noto forum cybercriminale in lingua inglese presente prevalente nel dark web. Ospita una varietà di contenuti illeciti, tra cui informazioni personali, identità, informazioni su carte di credito e strumenti per l'hacking. Nonostante il suo focus illegale, viene fatta passare come una comunità per condividere leak e partecipare a semplici discussioni.

Nel 2016, Nulled è stato reso famoso a causa di una grave data breach che ha esposto informazioni personali di migliaia di utenti. Nonostante i rischi, continua ad essere accessibile dal web pubblico che dal dark web, attirando utenti con diversi livelli di accesso.

7. **RAMP:** Fondato nel luglio 2021, RAMP (Russian Anonymous Market Place) si distingue tra i forum del dark web di lingua russa, cinese e inglese. Il forum mantiene politiche rigorose per l'adesione, con una delle più cruciali, ciò avere una buona reputazione sui altri forum, come XSS e Exploit. RAMP è aumentato in popolarità capitalizzando sugli effetti dell'attacco al Colonial Pipeline negli Stati Uniti, sfruttando i suoi effetti sul dark web.

Dopo l'attacco al Colonial Pipeline, molti forum hacker hanno imposto restrizioni sui dati relativi in particolare ai gruppi ransomware. Servendo come punto vitale per i gruppi di Ransomware-as-a-Service (RaaS), RAMP ha poi riservato un'area nel suo "programma partner" per questi gruppi e per dar loro la possibilità di condurre attività come il reclutamento di nuovi hacker o la vendita di credenziali.

8. **Cracked:**

Cracked opera come un forum attivo sul web di superficie. Come lingua principale utilizza l'inglese e le discussioni riguardano prevalentemente dati, vulnerabilità, credenziali e strumenti illeciti. Il forum presenta anche 12 sottoforum dedicati ad altre lingue, con il sottoforum in francese che risulta essere il più attivo.

9. **CraxPro:**

Fondato nel 2020 è un forum in lingua inglese, all'interno del quale le discussioni ruotano attorno a temi come la vendita di passaporti/ID, la vendita di cookie e credenziali, database, vendita di proxy SOCKS4 e carte di credito. Sebbene l'attività legata alle frodi con carte di credito possa talvolta superare quella di Altenen, gli utenti che le utilizzano suggeriscono che le informazioni sono spesso imprecise.

10. **Dread:**

Fondato nel 2018, come lingua principale è utilizzato l'inglese, Dread è stato fondato dall'hacker come HugBunter. Soprannominato "Reddit del dark web" per la sua interfaccia simile. Dread è uno dei più grandi forum del dark web, bensì i temi di sicurezza, vulnerabilità e intelligence siano presenti le discussioni sulla vendita di stupefacenti spesso oscurano il resto degli argomenti.

[10]

3.5 Analisi delle Tendenze e Prevenzione

Per verificare e prevenire che le informazioni aziendali non siano state illegalmente pubblicate o sottratte, è possibile svolgere una serie di attività per mantenere protette le informazioni e assicurarsi che lo rimangano:

Cerca informazioni con l'utilizzo di OSINT, determinando quali informazioni l'organizzazione è disposta a rendere pubbliche e se l'organizzazione ha il controllo su queste informazioni. Da queste informazioni sarà possibile creare un elenco di tutte le vulnerabilità che eventuali hacker possono utilizzare a loro vantaggio. Sarà in oltre possibile gestire e configurare al meglio i sistemi in modo tale da non divulgare informazioni che non si vuole vengano rese pubbliche.

Sarà poi di primaria importanza una continua formazione sulla cybersecurity. Per identificare vulnerabilità e correggere falle di sicurezza. Addestrando al meglio i dipendenti e preparandoli ad affrontare al meglio potenziali attacchi, investendo in programmi di formazione continua per i dipendenti

per migliorare la consapevolezza sulla sicurezza informatica, come il riconoscimento delle email di phishing, la gestione delle password e la risposta agli incidenti. L'elemento umano è spesso l'anello più debole, quindi l'educazione e la sensibilizzazione sono cruciali e creando SOP (Procedure Operative Standard).[5]

Da notare che OSINT è sia un vantaggio che un rischio per la sicurezza di un'organizzazione. In quanto è possibile usare OSINT per identificare punti deboli e migliorare la sicurezza; ma questo permette anche a potenziali hacker di sfruttare le minacce e utilizzare le stesse informazioni per lanciare attacchi mirati ed efficaci. Ecco perché è fondamentale che le organizzazioni siano consapevoli dei potenziali rischi associati a OSINT e prendano misure per proteggere le loro informazioni sensibili.

Sarà necessario effettuare un monitoraggio costante delle tendenze, restando aggiornati sulle ultime minacce e collaborando con team di Threat Intelligence per raccogliere informazioni sulle nuove vulnerabilità, attori e tattiche, tecniche e procedure (TTP) utilizzate. Utilizzando fonti di OSINT (Open Source Intelligence), dark web monitoring e rapporti da agenzie di sicurezza.

È poi fondamentale implementare sistemi di Difesa a più livelli, utilizzando un approccio di difesa in profondità che includa firewall, sistemi di prevenzione delle intrusioni (IPS), antivirus, antimalware, e sistemi di rilevamento delle minacce basati su intelligenza artificiale (per identificare comportamenti anomali, rilevare e rispondere a minacce zero-day e automatizzare la gestione degli incidenti. L'automazione riduce il tempo di risposta e limita l'esposizione alle minacce).

Ulteriori attività di prevenzione:

1. Per prevenire futuri attacchi sarà utile di simulare attacchi e penetration testing, in quanto condurre regolari penetration testing e simulazioni di attacchi (come il Red Teaming) per identificare punti deboli nella rete aziendale e nelle infrastrutture di sicurezza, permetteranno una valutazione realistica della postura di sicurezza dell'organizzazione. Pianificando e preparando Incident Response, sviluppando e mantenendo aggiornato un piano di risposta agli incidenti (IRP) che stabilisca chiare procedure operative per affrontare potenziali violazioni della sicurezza, permetterà ai team di essere sempre preparati.
2. Ottenere una copertura di assicurazione contro i rischi cyber per mitigare le perdite finanziarie derivanti da attacchi informatici.
3. Adottare soluzioni di sicurezza per proteggere gli endpoint (laptop, dispositivi mobili, server) e le infrastrutture cloud. Implementare po-

litiche di sicurezza zero-trust, che prevedono il controllo rigoroso degli accessi e la segmentazione della rete.

4. Stabilire un team di Cyber Threat Hunting per cercare proattivamente minacce avanzate che potrebbero non essere rilevate dai sistemi di difesa tradizionali.
5. Monitorare il dark web per rilevare dati aziendali rubati, informazioni sensibili o qualsiasi menzione dell'azienda che potrebbe indicare un attacco imminente. I servizi di monitoraggio dei social media possono aiutare a identificare campagne di phishing o minacce di insider.
6. Sviluppare un'architettura di sicurezza scalabile che possa crescere con l'azienda. Questo include la protezione delle API, l'uso di DevSecOps⁵ per integrare la sicurezza nello sviluppo del software e la crittografia dei dati sensibili a riposo e in transito.

3.6 Minacce Emerse dal Dark Web

Utilizzare il dark web per indagini OSINT comporta diversi rischi significativi che richiedono una gestione attenta:

Esposizione a Contenuti Illegali e Disturbanti: Il dark web ospita infatti una vasta quantità di materiale illegale e potenzialmente traumatico non censurato, presentando dilemmi legali ed etici per gli investigatori.

Tracce Digitali: Gli investigatori devono essere estremamente cauti per evitare di lasciare tracce digitali, che potrebbero compromettere la loro identità e l'indagine. Sono necessarie competenze e strumenti specializzate per accedere al dark web e navigarlo in modo sicuro e anonimo.

Sono presenti Informazioni Inaffidabili e potenzialmente sbagliate: Le informazioni raccolte dal dark web potrebbero non essere sempre affidabili o accurate, richiedendo una valutazione quindi una valutazione attenta.

Struttura non adeguata e Difficoltà di Ricerca: Il dark web non è indicizzato dai motori di ricerca e gli indirizzi cambiano frequentemente, rendendo difficile la ricerca e il monitoraggio di prove che possono rapidamente scomparire.

⁵Development, Security, and Operations è un approccio integrato allo sviluppo del software che incorpora pratiche di sicurezza informatica direttamente nel ciclo di vita dello sviluppo del software (SDLC)

Potenziali Implicazioni Legali: Accedere al dark web può comportare rischi legali, poiché un'investigatore potrebbero essere scambiato per un hacker dalle forze dell'ordine.

Minacce di Malware e Hacking: Esistono rischi di sicurezza intrinseci nell'accesso al dark web, come malware e tentativi di hacking che potrebbero interrompere un'indagine e mettere a repentaglio la sicurezza di un'utente.

Per verificare la veridicità dei dati, e limitare il rischio derivante dalle attività sul Dark Web è possibile svolgere le seguenti operazioni:

Cross-Reference con risorse del web pubblico:
Confrontando i dati del dark web con le informazioni disponibili sul web pubblico per identificare inconsistenze. Verificare nomi utente, informazioni di contatto e schemi di attività su più piattaforme.

Valutare l'affidabilità delle informazioni sul Dark Web:
Valuta la reputazione e la credibilità dei forum del dark web, dei marketplace e dei servizi di messaggistica utilizzati come fonti di dati.

Analizzare pattern e anomalie:
Cerca schemi nei dati coerenti con attività criminali note, identifica anomalie e incoerenza nei dati e svolgi ulteriori indagini.

Utilizza le informazioni e le risorse di media di divulgazione:
Confronta i dati del dark web con le informazioni provenienti da questi siti, migliorando l'affidabilità dei dati.

Verifica i dati con gli esperti:
Collabora con le forze dell'ordine, professionisti della cybersecurity e analisti dell'intelligence esperti in indagini sul dark web. Sfrutta la loro esperienza per verificare dati del dark web.

In fine verifica che tutti i dati raccolti dal dark web siano stati ottenuti legalmente ed eticamente.

Capitolo 4

Tools e Tecnologie

Esploriamo ora i principali strumenti e le tecnologie OSINT che possono essere utilizzate per monitorare e analizzare le attività del dark web. Questi strumenti permettono alle aziende e alle organizzazioni di individuare le proprie vulnerabilità, raccogliendo informazioni sui dati esposti e sulle potenziali minacce. L'individuazione dei possibili punti deboli, che possono favorire un attacco, è fondamentale per rafforzare le difese di sicurezza informatica e prevenire attacchi mirati.

Di seguito, vedremo i principali tools utilizzati per raccogliere, analizzare e proteggere le infrastrutture aziendali nel contesto della Cybersecurity.



Figura 4.1: Tipologie di strumenti per la cybersecurity

Studieremo ora gli strumenti, analizzando le loro caratteristiche principali, funzionalità e utilizzi. Ogni strumento offre un set unico di capacità che possono essere utilizzate per supportare le operazioni di intelligence e sicurezza. Tra questi, includiamo framework di raccolta OSINT come OSINT Framework, strumenti di data mining come Maltego, motori di ricerca per dispositivi come Shodan e Censys, piattaforme di penetration testing come Metasploit,

4.1 OSINT Framework

OSINT Framework è una directory completa di strumenti e risorse OSINT gratuiti disponibili online, ospitata sulla piattaforma per sviluppatori GitHub. Questo framework rappresenta un punto di partenza ideale sia per hacker che per investigatori di cybersecurity che cercano strumenti specifici per la raccolta, l'elaborazione, l'analisi di intelligence. Include una vasta gamma di dati provenienti da internet, piattaforme di social media, registri pubblici, notiziari, pubblicazioni accademiche e altri materiali open-source, offrendo un supporto strutturato per approfondire le funzionalità necessarie in un ambiente di intelligence.

4.1.1 Caratteristiche e Utilizzo

OSINT Framework garantisce:

1. Opera entro i confini legali ed etici, poiché si basa su informazioni disponibili pubblicamente. Questo riduce i rischi associati all'accesso non autorizzato ai dati, garantendo la conformità con le leggi e le normative.
2. Il framework OSINT consente la raccolta e l'analisi di informazioni provenienti da una vasta gamma di fonti aperte, fornendo una visione completa del panorama dell'intelligence. Questo approccio può rivelare connessioni, che potrebbero non essere evidenti con l'utilizzo di una singola fonte, portando a decisioni più accurate.
3. Il framework OSINT permette una raccolta proattiva di intelligence, consentendo alle organizzazioni di anticipare e rispondere a potenziali minacce. Monitorando continuamente le fonti, gli analisti possono identificare tendenze emergenti.
4. La versatilità del framework OSINT lo rende applicabile a una vasta gamma di domini e soggetti.

5. Il framework OSINT è dinamico e adattabile, consentendo l'aggiunta di nuovi strumenti, tecniche e metodologie man mano che il panorama evolve.

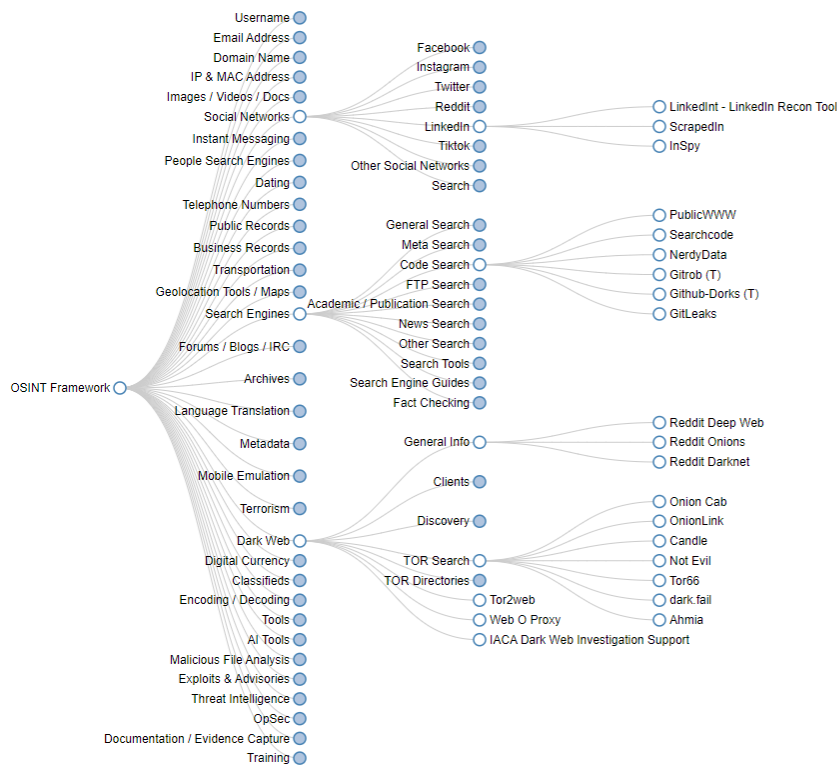


Figura 4.2: OSINT Framework

4.2 Maltego

Maltego è una soluzione di data mining in tempo reale e di analisi visiva disponibile per Windows, Mac e Linux. Questo strumento è progettato per identificare e visualizzare le relazioni tra varie tipologie di informazioni, come dati personali, dati aziendali, indirizzi IP, domini, e altro ancora, fornendo rappresentazioni grafiche di dati e connessioni. Ha la capacità di profilare e tracciare le attività online degli utenti, ed è estremamente utile per gli investigatori impegnati nella sicurezza informatica, per mappare connessioni tra utenti sospetti e attività di cybercrime, individuare minacce, hacker, e per gli analisti per identificare possibili minacce per l'organizzazione.

4.2.1 Caratteristiche e Utilizzo

1. Esegue il data mining in tempo reale da diverse fonti online e locali, recuperando informazioni come indirizzi IP, nomi di dominio, indirizzi email, identità sui social media e numeri di telefono.
2. Una delle caratteristiche di Maltego è la sua capacità di visualizzare relazioni complesse tra diversi tipi di dati. Utilizza grafici per mostrare le connessioni tra nodi rilevate, rendendo facile per gli analisti vedere come le informazioni sono collegate tra loro.
3. Maltego utilizza "Transforms"¹ per convertire una tipologia di informazione in un'altra.
4. Gli utenti possono personalizzare le Transforms, i grafici e le visualizzazioni in base alle loro esigenze specifiche, rendendo lo strumento completamente customizzabile.
5. È poi possibile integrare Maltego con altre piattaforme di intelligence come Shodan, Censys ecc.



Figura 4.3: Esempio di tracciamento con Maltego

¹O Trasformate, sono una serie di funzioni o blocchi che permettono di estrarre e analizzare informazioni da varie fonti, essenzialmente script o moduli per trasformare i dati

4.3 SpiderFoot

SpiderFoot è uno strumento di Open Source Intelligence che integra dati da una vasta gamma di fonti, inclusi il dark web, il surface web, e diverse API. È in grado di raccogliere informazioni come indirizzi e-mail, numeri di telefono, indirizzi IP, sottodomini e molto altro, offrendo un'ampia panoramica delle informazioni pubblicamente disponibili, che potrebbero rappresentare una minaccia per un'organizzazione o un individuo. SpiderFoot è uno strumento prezioso per hacker etici e professionisti della cyber security, è ideale per la scoperta automatizzata di informazioni sensibili e può essere utilizzato per scansionare il dark web alla ricerca di credenziali compromesse, dati all'interno di forum frequentati da hacker, o discussioni su potenziali vulnerabilità.

4.3.1 Caratteristiche e Utilizzo

1. Esegue la raccolta automatizzata di informazioni da oltre 200 fonti OSINT, come DNS, registri WHOIS, motori di ricerca, piattaforme di social media, dark web e altre API pubbliche.
2. Offre una vasta gamma di moduli che possono essere configurati per adattarsi alle esigenze specifiche dell'utente.
3. Offre sia un'interfaccia web user-friendly sia CLI, consentendo agli utenti di eseguire scansioni e analizzare i risultati in modo flessibile.
4. Supporta l'integrazione con strumenti di sicurezza popolari e framework di analisi come Maltego, MISP e altre piattaforme di sicurezza e produce report che possono essere esportati in diversi formati (PDF, CSV, JSON).

4.4 Shodan

Shodan è un motore di ricerca online che consente di identificare server, router, webcam, e altri dispositivi esposti pubblicamente. Definita anche il "Google dei dispositivi IoT"² Fornisce informazioni dettagliate sui metadati di numerosi dispositivi, sulle porte aperte e sulle vulnerabilità rilevabili. Grazie alla sua capacità di identificare dispositivi non sicuri o esposti, Shodan è uno strumento potente sia per i professionisti in ambito cybersecurity sia che

²L'Internet of Things è una rete di oggetti e dispositivi connessi e dotati di sensori e altre tecnologie che consentono loro di trasmettere e ricevere dati.

per i criminali informatici. Può essere utilizzato per scoprire se i dispositivi di un'organizzazione sono visibili su Internet e se sono esposti a vulnerabilità note, un aspetto cruciale per prevenire attacchi mirati da parte di hacker che sfruttano il dark web per trovare bersagli facili.

4.4.1 Caratteristiche e Utilizzo

1. Consente di trovare dispositivi esposti come server, router, telecamere IP, sistemi SCADA³, e altri dispositivi IoT. E fornisce informazioni su questi dispositivi.
2. É possibile configurare avvisi per essere notificati quando nuovi dispositivi compaiono nella rete.
3. Offre potenti filtri di ricerca che permettono di specificare dettagli come l'IP, il paese, il sistema operativo, il tipo di dispositivo e la versione del software.
4. Fornisce dashboard intuitive e include informazioni sulle Common Vulnerabilities and Exposures (CVE) associate ai dispositivi rilevati.

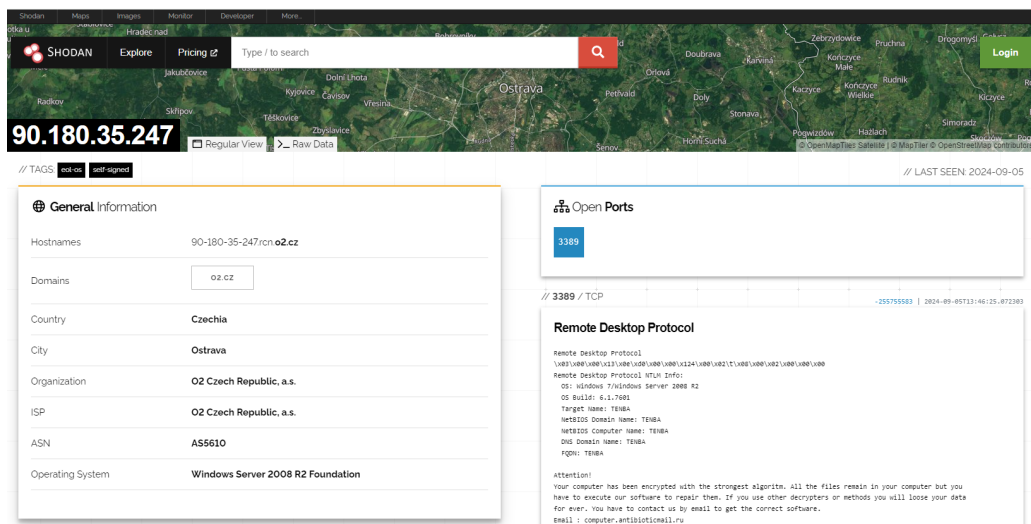


Figura 4.4: Server con Remote Desktop Protocol esposto

³Supervisory Control And Data Acquisition, sono sistemi con gli obbiettivi di supervisione, controllo e acquisizione dati.

4.5 Have I Been Pwned (HIBP):

Have I Been Pwned è un servizio disponibile sul clear web che consente di verificare se le credenziali aziendali o personali sono state compromesse in un data breach. Offre un database consultabile dove gli utenti possono controllare se i loro indirizzi email o le loro password sono presenti in data breach noti. È uno strumento essenziale per le organizzazioni, poiché permette di monitorare regolarmente se le credenziali dei dipendenti sono state esposte in violazioni di dati. In caso di compromissione, consente di reagire rapidamente aggiornando le password e implementando misure di sicurezza aggiuntive, come l'autenticazione a più fattori, per mitigare i rischi di ulteriori attacchi.

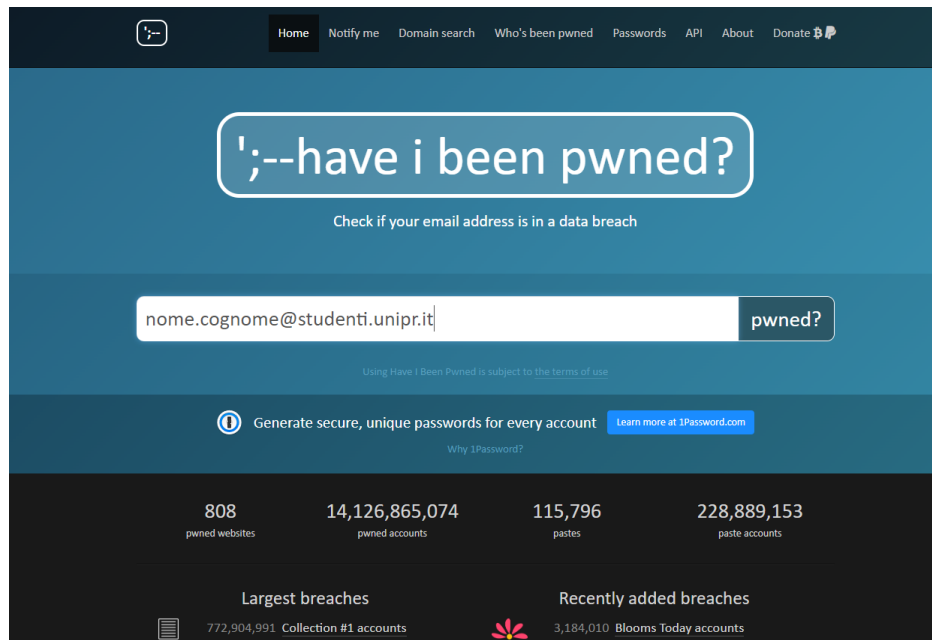


Figura 4.5: Textbox di HIBP per la verifica di credenziali

4.5.1 Caratteristiche e Utilizzo

1. Il database mantiene un vasto database di violazioni e al momento include miliardi di record provenienti da centinaia di data breach.
2. Gli utenti possono cercare i propri indirizzi email per vedere se sono stati compromessi. E le aziende possono verificare se i domini aziendali sono presenti nei data breach per monitorare se sono presenti le credenziali dei loro dipendenti.

3. Consente agli utenti di iscriversi al sito per ricevere un avviso in caso di nuove violazioni di dati che coinvolgono le loro credenziali.
4. Permette di verificare se una password è stata esposta in una violazione di dati e offre un'API per dare la possibilità alle aziende di integrare questi controlli nei loro sistemi.

4.6 Altri strumenti utili:

Burp Suite:

Burp Suite è uno strumento di test di sicurezza delle applicazioni web utilizzato per identificare e analizzare vulnerabilità in siti web e applicazioni online. Questo software fornisce un set completo di strumenti integrati che consentono di effettuare il crawling, lo scanning, l'analisi e la manipolazione del traffico HTTP/S. È ampiamente utilizzato da penetration tester e professionisti della sicurezza per eseguire test di sicurezza manuali e automatizzati, individuando problemi come sql injection, cross-site scripting (XSS), e altre vulnerabilità comuni. Grazie alla sua interfaccia user-friendly e alla possibilità di aggiungere estensioni, Burp Suite è considerato uno dei tool più versatili per la sicurezza delle applicazioni web.

Metasploit:

Metasploit è una piattaforma avanzata per il penetration testing che consente di identificare, verificare e sfruttare le vulnerabilità di sicurezza presenti in reti, sistemi, e applicazioni. Utilizzato da cybersecurity analyst, ricercatori e anche da hacker, Metasploit offre una vasta libreria di exploit, payload, e moduli per testare la sicurezza di un'infrastruttura IT. La piattaforma supporta sia attacchi manuali che automatizzati, permettendo di simulare scenari di attacco reali per valutare l'efficacia delle difese di un'organizzazione. Oltre all'identificazione delle vulnerabilità, Metasploit può essere utilizzato per test di sicurezza approfonditi, auditing, e per il miglioramento delle strategie di mitigazione dei rischi, rendendolo uno strumento versatile e indispensabile nel campo della sicurezza informatica.

Recon-ng:

È uno strumento, open-source scritto in Python, per la ricognizione e raccolta dati, progettato per automatizzare il processo di OSINT durante le attività di penetration testing e cybersecurity. È simile a Metasploit per la sua struttura modulare, ma è specificamente focalizzato sulle fasi iniziali di

un attacco, in cui gli eventuali hacker cercano di raccogliere il maggior numero informazioni su un bersaglio (come domini, indirizzi IP, persone, aziende, ecc.) da fonti pubblicamente disponibili. È altamente modulare, consentendo agli utenti di aggiungere, rimuovere e aggiornare facilmente i moduli, presenta un'interfaccia a CLI⁴ simile a quella di Metasploit, con la possibilità di eseguire comandi come add, remove, run e show. Offre poi la possibilità di generare report dettagliati in vari formati, come HTML, JSON, o CSV. Raccolge i dati in database che poi è possibile consultare attraverso delle query.

Ahmia:

Definito come il motore di ricerca del dark web, è uno degli strumenti più conosciuti e utilizzati per navigare e ricercare contenuti sul dark web in modo sicuro e organizzato. È uno dei pochi strumenti progettati appositamente per permettere la ricerca di siti .onion all'interno della rete TOR. A differenza di altri motori di ricerca Ahmia adotta criteri di indicizzazione rigorosi. Filtra i risultati per evitare la visualizzazione di contenuti illegali o dannosi, o quelli legati a malware e attività criminali. È accessibile sia dal clear web che dalla rete Tor, è un progetto open source⁵ (il che garantisce un elevato livello di trasparenza riguardo alle sue operazioni), e facilita l'identificazione di tendenze emergenti o threats grazie alla sua capacità di indicizzare e filtrare il dark web. Ahmia non traccia gli utenti e protegge la loro privacy, mantenendo una blacklist di siti che violano i suoi termini di servizio.

Censys:

Censys è una piattaforma di ricerca e analisi che, simile a Shodan, scansiona e fornisce informazioni dettagliate sugli asset connessi a Internet, come server, dispositivi IoT e servizi web. Tuttavia, Censys si distingue per le sue capacità di analisi più approfondite e per la sua interfaccia avanzata, che consente agli utenti di ottenere una visione più completa della superficie di attacco di un'organizzazione. La piattaforma offre anche funzionalità di monitoraggio continuo e avvisi personalizzati sulle esposizioni dei dati, permettendo di individuare rapidamente eventuali vulnerabilità o configurazioni errate. Per un'azienda, l'utilizzo di Censys è fondamentale per monitorare gli asset esposti su Internet e mitigare i rischi di accessi non autorizzati, riducendo così la probabilità di essere bersaglio di attacchi.

Nmap:

È uno strumento open-source utilizzato per la scansione e l'analisi di reti, di-

⁴Riga di Comando

⁵Il suo codice è aperto e disponibile per la revisione da parte della community

sponibile per Windows, Linux e macOS. È uno dei tool più popolari e potenti nel campo della sicurezza informatica e del penetration testing, ed è ampiamente utilizzato da amministratori di rete, analisti di sicurezza, e hacker per la raccolta di informazioni su reti, sistemi e dispositivi. Nmap è famoso per la sua capacità di eseguire scansioni sulle porte di un host o su una rete, identificando quali porte sono aperte e quali chiuse o filtrate. Questo permette di determinare quali servizi stanno girando su una macchina e di conseguenza se ci sono potenziali vulnerabilità sfruttabili. Può identificare il sistema operativo di un dispositivo, può anche identificare i servizi che stanno girando su quelle porte (ad esempio, un server web su HTTP o un server FTP⁶). Il Nmap Scripting Engine (NSE) è una delle sue funzionalità più importanti, e consente di eseguire script che possono automatizzare un'ampia gamma di attività di rete, dal rilevamento di vulnerabilità comuni all'esecuzione di attacchi di brute-force, è progettata per essere efficiente anche operando su una grande mole di dati.

Dark Web Monitoring Tools (ad esempio, DarkOwl, Recorded Future):

Questi sono strumenti avanzati progettati per aiutare le organizzazioni a monitorare il dark web alla ricerca di informazioni compromesse riguardo l'azienda. Questi strumenti possono identificare dati sensibili come credenziali violate, documenti riservati, o discussioni su possibili attacchi futuri che potrebbero rappresentare una minaccia per la sicurezza aziendale. Offrono un monitoraggio continuo delle menzioni di un'organizzazione sul dark web, consentendo di individuare rapidamente eventuali fughe di dati o attività sospette pianificate contro l'azienda. Questa capacità di rilevamento tempestivo è cruciale per prevenire danni, permettendo alle organizzazioni di adottare misure di risposta rapida e rafforzare le loro difese di sicurezza.

DarkOwl:

È una piattaforma di intelligence specializzata nella raccolta, analisi e monitoraggio di dati dal dark web, dal deep web e altre fonti non indicizzate dai motori di ricerca tradizionali. Viene utilizzato da diversi attori, DarkOwl aiuta le organizzazioni a identificare minacce, informazioni compromesse e attività malevole che potrebbero rappresentare un rischio per la sicurezza. utilizza tecnologie avanzate per la raccolta automatizzata di dati dal dark web, e si focalizza su "Darknet Intelligence" (DarkInt), ossia l'intelligence derivata da contenuti e attività nascoste nel dark web. Infine fornisce una

⁶File Transfer Protocol è un protocollo di comunicazione usato per il trasferimento di file da un server a un client

dashboard intuitiva per l'analisi e la visualizzazione dei dati.

Recorded Future:

È una piattaforma di Threat Intelligence basata sull'intelligenza artificiale e sull'analisi predittiva, progettata per aiutare le organizzazioni a identificare e mitigare le minacce alla sicurezza informatica in modo proattivo, unisce dati raccolti da milioni di fonti, allo scopo di fornire informazioni dettagliate e contestuali sulle minacce informatiche. Utilizza algoritmi di machine learning e NLP⁷ per analizzare automaticamente grandi volumi di dati. Una delle caratteristiche distintive è la sua capacità di fornire informazioni per ogni minaccia identificata (chi è coinvolto, la cronologia degli eventi, le motivazioni degli attaccanti, e la potenziale gravità).

Threat Intelligence Platforms (TIPs):

Le piattaforme come MISP (Malware Information Sharing Platform) sono strumenti utilizzati per raccogliere, organizzare e condividere informazioni riguardanti minacce note ed emergenti. Questi strumenti permettono di centralizzare le informazioni per facilitare l'analisi e la risposta alle stesse. Le TIPs aiutano le organizzazioni a gestire i dati OSINT raccolti sulle minacce conosciute, supportando la definizione di contromisure efficaci. Permettono di monitorare proattivamente le minacce, consente di rafforzare la sicurezza complessiva, e rispondere a potenziali rischi in modo tempestivo.

Social Media Intelligence Tools:

Questi strumenti (ad esempio, Social Searcher, Mentionlytics) consentono di monitorare le menzioni dell'azienda e dei suoi dipendenti sui social media, piattaforme spesso sfruttate dagli hacker per raccogliere informazioni e preparare attacchi mirati. Utilizzando questi strumenti, le organizzazioni possono individuare potenziali campagne di phishing, disinformazione, o attacchi di social engineering pianificati. Questo monitoraggio aiuta a prevenire incidenti e a mantenere alta la reputazione dell'azienda, permettendo di reagire tempestivamente a minacce emergenti.

VPN e TOR:

L'utilizzo di VPN e del browser TOR è cruciale per garantire sicurezza e anonimato durante le attività di monitoraggio del dark web. Questi strumenti criptano il traffico internet e nascondono l'indirizzo IP dell'utente, rendendo difficile la tracciabilità. Minimizzare il rischio di rilevamento da parte di hacker è fondamentale per chi conduce operazioni di intelligence sul dark web.

⁷Natural Language Processing

Utilizzando VPN e Tor, gli investigatori possono navigare in modo sicuro e anonimo, riducendo al minimo le possibilità di essere identificati o monitorati durante le indagini su attività sospette o minacce emergenti.

Elastic Stack (ELK):

Elastic Stack, comunemente noto come ELK Stack, è una suite di strumenti open source composta da Elasticsearch, Logstash, e Kibana, progettata per la ricerca, l'analisi e la visualizzazione di grandi volumi di dati in tempo reale. **Elasticsearch** è un motore di ricerca e analisi distribuito, **Logstash** è uno strumento per l'ingestione, l'elaborazione e l'arricchimento dei dati, mentre **Kibana** offre potenti funzionalità di visualizzazione dei dati e creazione di dashboard. Elastic Stack è ampiamente utilizzato sui log provenienti da diversi sistemi all'interno di un'organizzazione. Nel contesto della sicurezza informatica, può essere impiegato per monitorare i segnali di compromissione (Indicators of Compromise, IoC), identificando potenziali minacce associate al dark web. L'ELK Stack consente di centralizzare i log di sicurezza, analizzare anomalie nel traffico di rete, tracciare attività sospette e generare avvisi in tempo reale, migliorando così la capacità dell'organizzazione di rilevare e rispondere rapidamente agli incidenti di sicurezza.

Splunk:

software che permette di cercare, monitorare e analizzare grandi volumi di dati generati da macchine in tempo reale. Viene utilizzato principalmente per l'analisi di log e per la gestione delle operazioni IT e per il monitoraggio delle applicazioni. Splunk può raccogliere dati da diverse fonti, come server, reti, applicazioni, sensori IoT, e sistemi operativi. Utilizza un proprio linguaggio di ricerca chiamato SPL (Search Processing Language) e offre strumenti per la visualizzazione dei dati attraverso grafici, dashboard, e report, che possono essere personalizzati per visualizzare l'andamento dei dati nel tempo.

Nessus:

Strumento per la scansione di vulnerabilità, utilizzato per identificare potenziali punti deboli, problemi di configurazione e falle di sicurezza in reti, server, applicazioni e altri dispositivi informatici. Nessus è in grado di eseguire scansioni su una vasta gamma di dispositivi e sistemi operativi, rilevando, vulnerabilità note, porte aperte, configurazioni errate, software obsoleto. Utilizza un vasto database di vulnerabilità aggiornato regolarmente. É possibile programmare scansioni automatiche a intervalli regolari, con i quali generare report dettagliati e creare report personalizzati.

MISP (Malware Information Sharing Platform):

Piattaforma open source progettate per facilitare la condivisione, l'aggregazione e l'analisi di informazioni relative alle minacce. Utilizzata da organizzazioni, governi e comunità di cybersecurity in tutto il mondo. È uno strumento utile per migliorare la consapevolezza situazionale delle minacce e la loro risposta. Consente la condivisione strutturata di informazioni su malware, indicatori di compromissione (IoC), tattiche, tecniche e procedure (TTP) degli attaccanti, vulnerabilità e altre informazioni utili. MISP è progettato per supportare la collaborazione tra diverse entità, come team di sicurezza interni, CERT⁸, CSIRT⁹, e altre entità di difesa dell'organizzazione. È dotato di robusti controlli di accesso e può essere integrato con altre piattaforme di sicurezza informatica attraverso API e script personalizzati.

Questi sono solo alcuni degli strumenti che andremo ad analizzare e ad utilizzare.

⁸Computer Emergency Response Teams

⁹Computer Security Incident Response Teams

Capitolo 5

Caso di Studio: Esempio Concreto

”Collecting information is an important early step (though not the first in the intelligence cycle) To get from raw information to a finished intelligence product, researchers must process and analyze the data to determine whether it’s relevant to the investigation and turn it into actionable insights. Which is why it’s essential to lead with the question of “why is this important,” rather than focus on which tools to use.” [11]

Raccogliere informazioni è uno step fondamentale in qualsiasi operazione di intelligence, in particolare è essenziale analizzare e definire quali sono i dati rilevanti, sulla quale concentrarsi per poter effettuare trasformazioni da dati grezzi in informazioni utili.

Ottenere ciò di cui si ha bisogno dal Dark web può essere complicato, è necessario quindi aver installato un browser specializzato, come TOR. Sarà inoltre fondamentale sapere quale dominio si sta cercando (poichè come sappiamo le pagine del dark web non sono indicizzate). Esistono tuttavia alcuni strumenti che è possibile utilizzare, (come Ahmia e Haystack), ma per la maggior parte del tempo si dovrà navigare nel dark web senza una mappa chiara.

I ricercatori OSINT trascorrono molto tempo raccogliendo informazioni da diverse piattaforme, per questo hanno ottimizzato metodologie, con le quali è possibile estrarre credenziali, nomi, domini, numeri di Whatsapp, account email Proton¹ ecc. Una volta raccolti i dati, tramite l’utilizzo dei social media e dei marketplace, sarà possibile analizzare e visualizzare le

¹É un servizio di posta elettronica gratuito e protetto, che utilizza la tecnologia SSL per proteggere la comunicazione tra il server e gli utenti

informazioni personali e tener traccia di modifiche o legami riguardo l'identità dei vari attori.

Parlando di dark web, è bene ricordare che in ambito di ricerca e raccolta dati, alcuni marketplace e forum sono specchiati sul web visibile, questo porta a numerosi vantaggi, in quanto possono offrire informazioni non visibili sul dark web, essendo spesso siti "pronti all'uso" e sviluppati con WordPress, NginX o altri CMS (Content Management System). Su questi siti specchio possono mancare restrizioni sulla privacy, possono rivelare informazioni sui server o esporre numerose informazioni.

Parlando di sicurezza di un'organizzazione: Bisogna sempre essere attenti al fatto che ogni azione, anche di un singolo dipendente, può portare all'esecuzione di uno script o un malware sul sistema, compromettendo l'intera organizzazione.

Trovare OSINT su un'organizzazione:

Le aziende sono tra i soggetti più facili da cui ottenere informazioni, poiché per la loro costituzione e operatività sono tenute a presentare diverse documentazioni presso enti pubblici. Questi documenti sono spesso facilmente accessibili e consultabili, fornendo a potenziali hacker una vasta gamma di informazioni dettagliate che possono facilitare un'attività di indagine.

Effettuando una ricerca sul sito web dell'azienda o sul Registro delle Imprese (gestito dalle Camere di Commercio), è possibile ritrovare una mole di dati fondamentale per iniziare a svolgere un'attività di monitoraggio e analisi.

I siti web rappresentano una grande fonte di informazioni su un'organizzazione, sia dal punto di vista tecnico che per la sua evoluzione e/o rebranding. Per le indagini OSINT, i siti web vengono spesso analizzati per le loro informazioni tecniche, per reperire informazioni quali, chi li ha registrati, che server sono in utilizzo e da quale software vengono gestiti. Tutte queste informazioni possono essere raccolte attraverso servizi e tools.

Infine il sito web aziendale, può mettere a disposizione un numero elevato di informazioni, per esempio file lasciati pubblici per errore o informazioni che potrebbero non essere più presenti ma essere stati parte del sito web in passato. Con strumenti come l'Internet Archive o la Wayback Machine possiamo visualizzare come si presentava un sito web e come è cambiato nel tempo, confrontandoli è possibile evidenziare cambiamenti organizzativi, nuovi collaboratori o dipendenti che non fanno più parte dell'organizzazione.

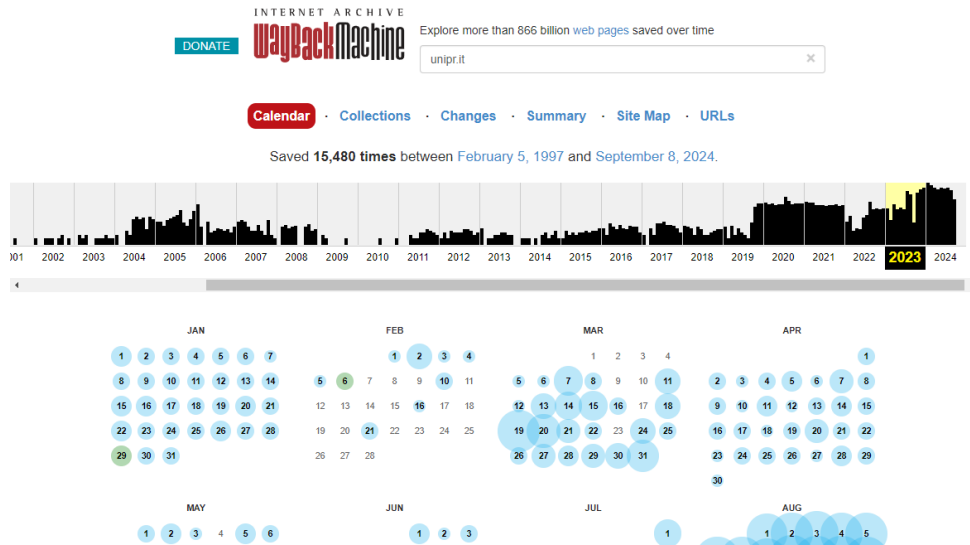


Figura 5.1: Wayback Machine

Vediamo poi il "Google Dorking"² che è un'altra modalità per trovare file e altri dettagli lasciati accidentalmente pubblici su Internet. Strutturando le query di ricerca di Google, alla ricerca di determinati tipi di pagine web o file, è facile trovare componenti o informazioni all'interno del sito web che potrebbero contenere informazioni riservate.[6]

5.1 Obiettivo

Gli obiettivi del caso di studio sono mirati a esaminare come il Dark Web possa essere utilizzato come risorsa OSINT di un'azienda, per la protezione dei propri asset. In particolare, l'obiettivo è quello di configurare e utilizzare una serie di vulnbox, ambienti appositamente creati, configurati e isolati per condurre attività di monitoraggio e analisi.

Questi ambienti consentiranno di simulare scenari realistici di raccolta dati, protezione e prevenzione, fornendo un terreno sicuro e circoscritto per sperimentare e comprendere le procedure operative standard (SOP) per la gestione degli incidenti di sicurezza. Attraverso l'utilizzo di strumenti come Maltego, SpiderFoot, Shodan, e piattaforme di monitoraggio del dark web come DarkOwl Vision o Recorded Future, verranno eseguite attività di raccolta di informazioni, identificazione di minacce, analisi delle vulnerabilità e monitoraggio delle menzioni aziendali nel Dark Web.

²I dork sono comandi utili per affinare i risultati di una ricerca, permettendo di trovare risultati precisi

È fondamentale per questo studio rilevare come sia possibile utilizzare i servizi presenti sul Dark Web per la protezione, tramite strumenti OSINT, dei dati e delle infrastrutture dell'organizzazione. Una volta identificato un attacco, verranno seguite una serie di procedure per il contenimento e la mitigazione del problema. Queste includeranno l'aggiornamento delle regole di sicurezza nei sistemi SIEM³, l'implementazione di contromisure adeguate come patching e rafforzamento delle configurazioni, e l'esecuzione di penetration testing per verificare l'efficacia delle difese.

Inoltre, sarà indispensabile implementare programmi di formazione continua per i dipendenti per aumentarne la consapevolezza sui rischi del dark web, del phishing e dell'ingegneria sociale. Infine, verrà preparato un piano di azione per il futuro, che includerà il monitoraggio continuo, la revisione periodica delle policy di sicurezza e la risposta agli incidenti per garantire la resilienza dell'organizzazione contro minacce emergenti.

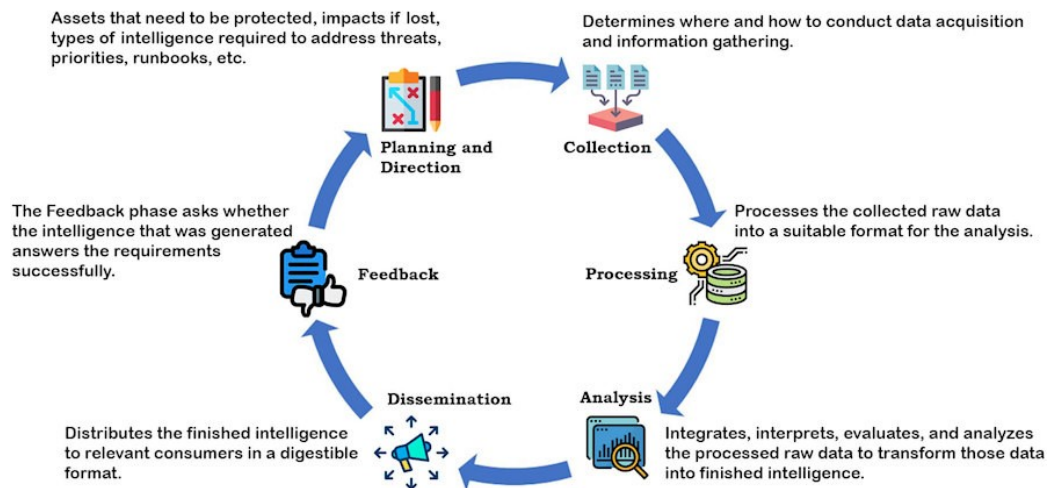


Figura 5.2: Cyber Threat Intelligence Cycle

Nel nostro caso concreto:

Considerando l'infrastruttura di una Startup tecnologica, impegnata nel fornire software di revenue management⁴, utilizzando i big data e sofisticati algoritmi di intelligenza artificiale, fa previsioni precise e utili sul comportamento di prenotazione degli utenti nell'acquisto di biglietti aerei per diverse

³Soluzione che consente alle organizzazioni di rilevare, analizzare e rispondere alle minacce di sicurezza prima che compromettano le operazioni aziendali.

⁴RMS, è un software che aiuta le aziende a ottimizzare il volume d'affari delle attività e per la gestione delle entrate in modo rapido ed efficiente.

compagnie. Il software è indispensabile per effettuare previsioni e per adattare in modo rapido ed efficiente le misure di comunicazione, di marketing e per adattare i prezzi al meglio.

Con l'aiuto di un database completo, in cui confluiscono tutti i dati sul comportamento di prenotazione, e di sofisticati strumenti analitici, i programmi di Revenue Management fanno previsioni sul comportamento dei futuri clienti.

La startup è di medie dimensioni con circa 70 dipendenti e è attiva da circa 5 anni, ha una presenza online consolidata, un'applicazione web, una mobile e un sito.

Questa startup può presentare vulnerabilità riguardanti il sito web principale (dedicata a clienti e partner), tramite i servizi di posta elettronica aziendale, tramite i dati sensibili dei clienti e i dati proprietari (codice sorgente ecc.).

Come vedremo subirà un attacco in cui le credenziali di accesso di dipendenti e amministratori di sistema verranno sottratte, e successivamente pubblicizzate su un forum presente sul Dark Web. Con lo scopo di avere un punto d'appoggio all'interno dei sistemi aziendali (per potersi appropriare del codice sorgente, di informazioni proprietarie ecc.), e di guadagnare riscattando l'organizzazione, criptando i dati aziendali e dei clienti con un attacco di tipo Ransomware, paralizzando così le operazioni.

Quest'attacco sarà il risultato di un incidente di sicurezza, causata da una email di phishing e diverse tattica di social engineering⁵. Gli analisti della startup utilizzeranno strumenti OSINT per monitorare forum di hacker e marketplace sul dark web, per cercare menzioni relative alla startup e dei suoi asset. Durante il monitoraggio, verrà rilevato un post su un forum di hacker dove un utente anonimo sta tentando di vendere credenziali rubate appartenenti ai dipendenti della startup.

Utilizzando strumenti di monitoraggio del dark web verranno raccolti dati e menzioni relative alla startup e verranno ricercate le connessioni tra l'attore malevolo e l'organizzazione.

Infine verranno fornite checklist per l'implementazione delle contromisure, configurati Sistemi di Monitoraggio Continui (ad esempio sistemi SIEM), verranno avviati programmi di formazione per l'organizzazione sui rischi del social engineering e del phishing, e verranno eseguiti regolarmente test di penetration testing.

⁵O ingegneria sociale è una tecnica di cyber attack basata sullo studio del comportamento delle persone col fine di manipolarle e appropriarsi di informazioni confidenziali

5.2 Preparazione dell'Ambiente di Lavoro

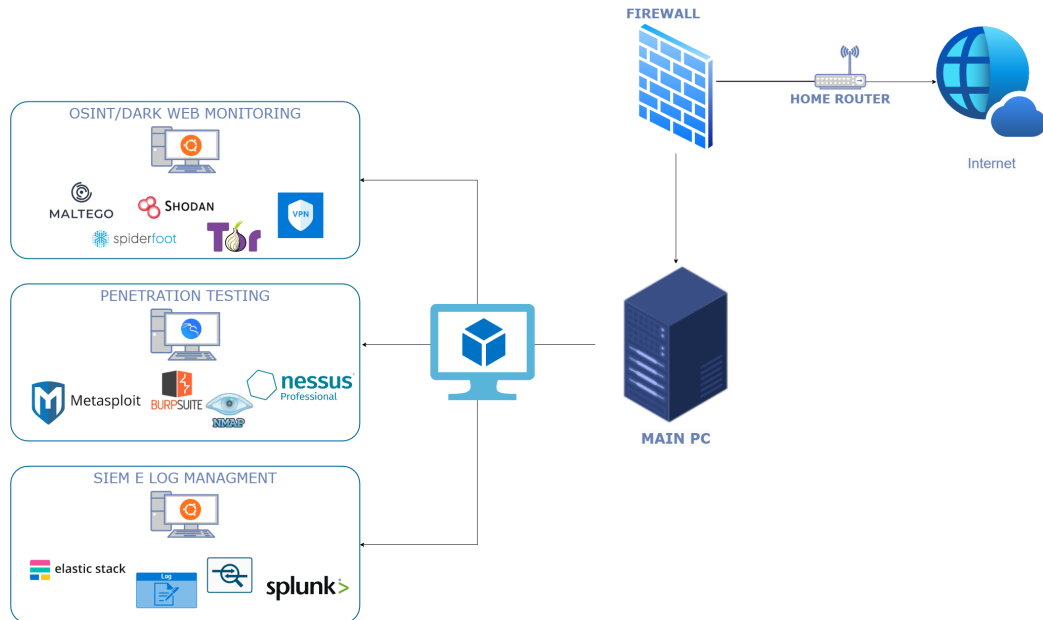


Figura 5.3: Infrastruttura ricreata in ambiente sandbox

Il sistema sarà formato da una macchina principale sotto la quale avremo l'integrazione di 3 ambienti.

Nello specifico tre macchine virtuali (o server) per le diverse funzioni⁶, tutte collegate a un Main PC che opera da host. È implementato l'uso di un firewall per proteggere il traffico di rete, per prevenire accessi non autorizzati e per monitorare il traffico in entrata e uscita. È implementato inoltre l'isolamento delle macchine virtuali per circoscrivere ciascuna funzione (monitoraggio, pentesting, Gestione degli eventi), per la sicurezza e per limitare i danni in caso di compromissione di una delle macchine.

1. **Macchina OSINT/Dark Web Monitoring:** Una macchina virtuale Linux (Con OS Ubuntu) configurata con strumenti di raccolta informazioni e navigazione sicura nel dark web. Questa macchina è utilizzata per raccogliere informazioni di intelligence e monitorare le attività nel dark web relative all'organizzazione. Con installati strumenti

⁶Opens Source Intelligence, Pentesting e SIEM (Security Information and Event Management)

come quali Maltego, SpiderFoot, Shodan. Sarà utilizzata per la raccolta automatizzata di informazioni da fonti pubbliche, dal dark web, per la scansione di servizi esposti e la raccolta di informazioni sulle vulnerabilità conosciute.

2. **Macchina SIEM e Log Management:** Un server dedicato con Elastic Stack o Splunk, configurato per raccogliere, analizzare e visualizzare i log di rete e di sistema. Questa macchina esegue simulazioni di attacco (es. penetration testing) per identificare e verificare le vulnerabilità nelle risorse esposte dell'organizzazione e per raccogliere log da varie fonti e visualizzare gli eventi in dashboard interattive secondo regole di correlazione.
3. **Macchina di Pentesting:** É una macchina virtuale con Kali Linux dedicata alle attività di penetration testing. Esegue simulazioni di diversi attacchi per identificare e verificare le vulnerabilità esposte dell'organizzazione. Utilizzando strumenti come Metasploit, Nmap, Burp Suite per testare le infrastrutture e le reti.

L'analisi dei dati si concentrerà sul Flusso di Informazioni OSINT e Dark Web verso i SIEM e il Log Management:

La macchina **OSINT/Dark Web Monitoring** raccoglie sia le informazioni pubbliche che quelle nel dark web relative all'organizzazione, come per esempio potenziali compromissioni, menzioni su forum di hacker, e credenziali esposte. I risultati pertinenti⁷ vengono inviati alla macchina SIEM e Log che creerà regole di correlazione e avvisi di sicurezza. Una volta analizzati, nel caso in cui venisse rilevata un'anomalia, credenziali compromesse o altri tipi di threat, il SIEM può essere configurato per monitorare l'utilizzo di quelle informazioni all'interno della rete interna e generare avvisi nel caso in cui venissero utilizzate.

Nel caso in cui il **SIEM e Log Management** identifichino attività sospette o vulnerabilità segnalate anche dagli avvisi, queste vengono trasmesse alla macchina di Pentesting, dove i penetration tester possono concentrarsi sulle aree identificate e segnalate come vulnerabili. Per esempio se il SIEM rileva traffico sospetto su una porta aperta, il team di pentesting può utilizzare strumenti come Nmap e Metasploit per testare ulteriormente quella specifica area, questi test mirati di attacchi brute force o exploit, serviranno per verificare l'efficacia delle misure di sicurezza impostate.

⁷indicatori di compromissione, indirizzi IP sospetti, Hash e domini malevoli

Alla fine i risultati ottenuti saranno utilizzati per aggiornare le regole di sicurezza del SIEM, per assicurare che futuri tentativi di attacco possano essere identificati e mitigati il prima possibile. In aggiunta le nuove minacce o exploit identificate, durante le attività di pentesting, possono suggerire la necessità di un'investigazione più approfondita delle informazioni OSINT e nel monitoring del Dark Web, in modo da prevenire potenziali exploit e attacchi zero-day⁸.

5.3 Raccolta di Dati tramite OSINT

Vediamo di seguito la raccolta e l'analisi di alcuni dati utilizzando il server di OSINT e Dark Web Monitoring, collegandoci alla macchina virtuale creata con Oracle VM VirtualBox, è possibile avviare il primo strumento con la quale andremo a verificare la possibile presenza di dati riguardanti la nostra azienda sul dark web.

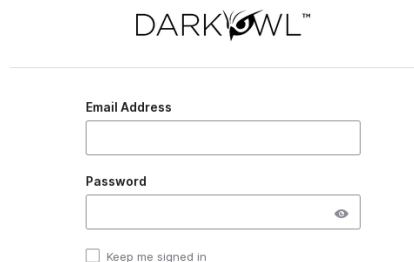
Per prima cosa andremo ad installare il browser TOR e a collegarci a una VPN.

```
SUDO APT INSTALL -Y TOR TORBROWSER-LAUNCHER
```

Registrare e successivamente eseguire tramite il terminale il nostro browser, posizionandosi sulla location delle cartelle di installazione:

```
./START-TOR-BROWSER.DESKTOP --REGISTER.APP
```

Possiamo poi collegarci e creare un account su Darkowl.



DARKOWL™

Email Address

Password

☐ Keep me signed in

Figura 5.4: Login di Darkowl

⁸Descrive vulnerabilità scoperte recentemente e utilizzate da hacker. Il termine "zero-day" si riferisce al fatto che il fornitore o lo sviluppatore è appena venuto a conoscenza della falla e quindi ha "zero giorni" di tempo per correggere l'anomalia

CAPITOLO 5. CASO DI STUDIO: ESEMPIO CONCRETO

Una volta create le credenziali di accesso, sarà possibile effettuare una ricerca con Darkowl Vision: Ci colleghiamo tramite il sito web, dove ci si presenta una barra di ricerca, con la quale potremo fare una ricerca sul nome dell'organizzazione, sul dominio o su qualsiasi dato che ci può interessare.

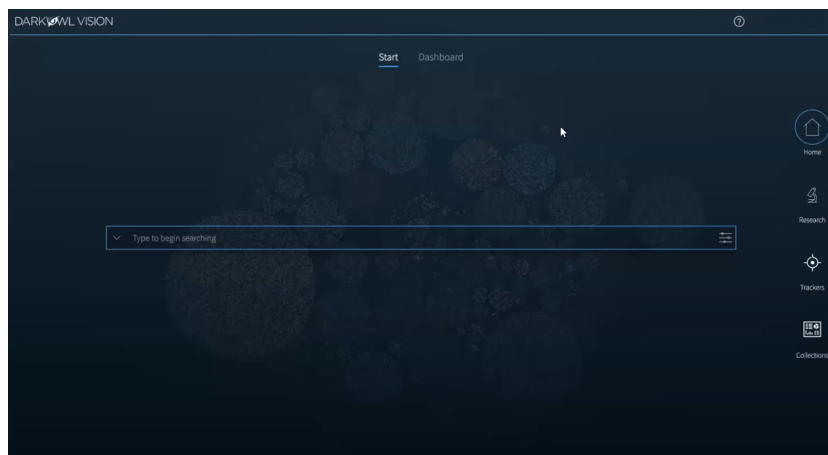


Figura 5.5: Landing page Darkowl

Andiamo a fare una ricerca utilizzando la keyword "wordpress.com", questo andrà a cercare sul dark web ogni menzione o dato presente (visitando forum, siti web, conversazioni ecc.) riguardano l'oggetto della ricerca:

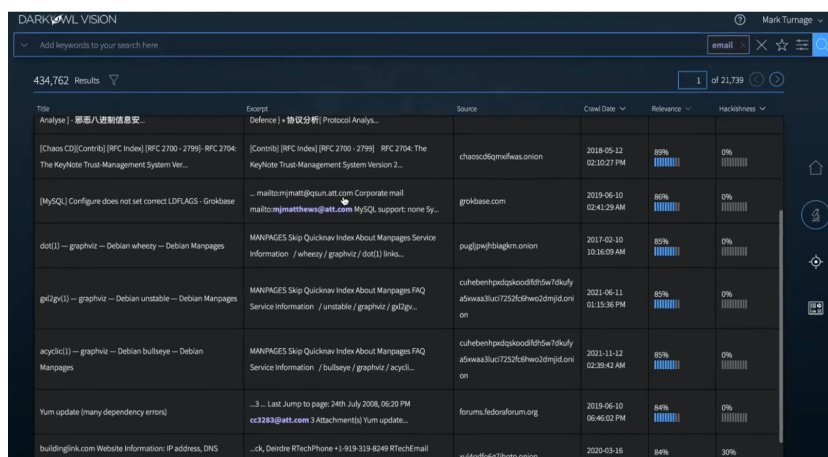


Figura 5.6: Risultato di una possibile ricerca

In questo caso possiamo vedere circa 434 mila risultati e navigando il sito possiamo vedere una serie di risultati, che possono essere email, credenziali o altre tipologie di informazione. I dati possono essere presentati in tanti modi differenti e organizzati/riordinati per data, nome o importanza.

CAPITOLO 5. CASO DI STUDIO: ESEMPIO CONCRETO

Vedremo per esempio un timestamp con il periodo di estrazione del dato dal dark web e sarà possibile ordinarli per rilevanza e "hackishness"⁹, questo indicatore sarà molto elevato nel caso in cui il risultato contenesse informazioni sensibili o possibili password in chiaro.

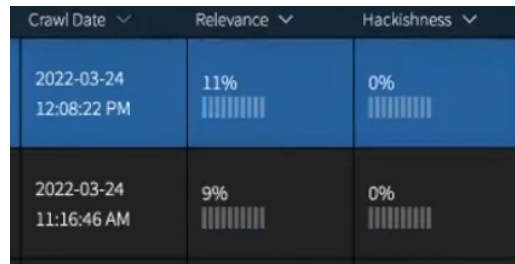


Figura 5.7: Rilevanza dell'output e hackishness

Come abbiamo visto, questo è uno strumento diretto e intuitivo, soprattutto per un team alla ricerca di informazioni specifiche o un possibile hacker alla ricerca di informazioni in chiaro sul darkweb.

Successivamente alla raccolta dei dati con l'utilizzo di uno strumento di data mining e organizzazione delle informazioni, per esempio maltego sarà possibile andare a identificare e visualizzare relazioni tra diverse informazioni o dati.

Prima di eseguire il programma sarà indispensabile installare una versione di java sul sistema operativo:

```
osintdw@OSINT-DW-MONITORING:/usr/bin$ sudo apt install openjdk-11-jdk
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following packages were automatically installed and are no longer required:
 gir1.2-goa-1.0 libfprint-2-tod1 libfwupdplugin1 libllvm9 libxmlb1
Use 'sudo apt autoremove' to remove them.
The following additional packages will be installed:
 ca-certificates-java fonts-dejavu-extra java-common libatk-wrapper-java
 libatk-wrapper-java-jni libice-dev libpthread-stubs0-dev libsm-dev
 libx11-dev libxau-dev libxcb1-dev libxdmcp-dev libxt-dev
```

Figura 5.8: Installazione di Java

Terminato il download e l'installazione sarà possibile eseguire il programma e creare un nuovo mappatura (successivamente alla creazione di un account sul sito ufficiale). Una volta selezionato il web browser ci verrà chiesto di scegliere tutti o una serie di transforms:

⁹Indica quanto è rilevante e pericoloso quel determinato risultato

CAPITOLO 5. CASO DI STUDIO: ESEMPIO CONCRETO

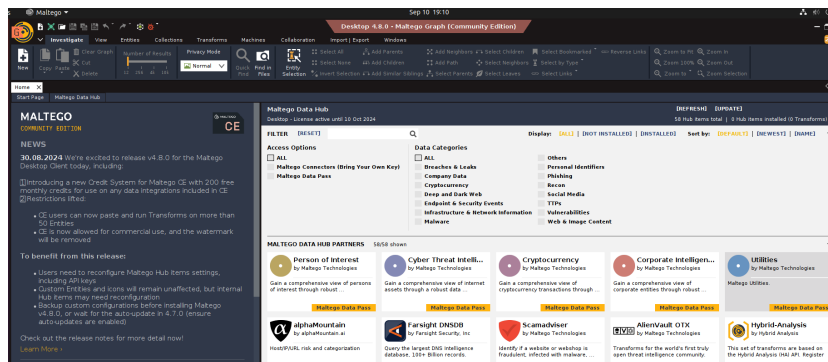


Figura 5.9: Transforms in Maltego

Scelti i trasform e il relativo API (per esempio filtrando solo per "Breaches e leaks, dark web e phishing" troveremo i seguenti API con la quale andare a creare le nostre ricerche:

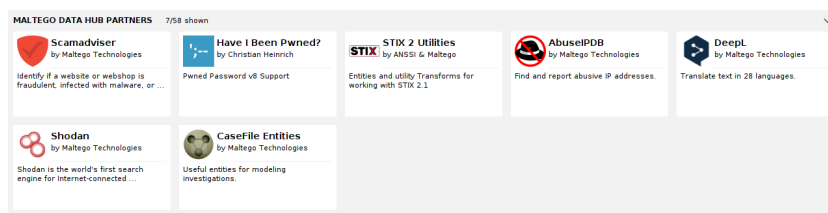


Figura 5.10: Transforms da utilizzare nel caso di una ricerca OSINT-Dark Web

Maltego mette a disposizione tantissimi tool e API che una volta installati, ci permetterà di creare una mappatura dei nostri dati, facendo una ricerca sui dati che abbiamo recuperato in precedenza o dati correlati.

Facendo una ricerca su una serie di entità, inserendo dati di cui siamo a conoscenza o chiedendo a Maltego (con l'utilizzo delle API installate) di recuperare informazioni (dal clear web e soprattutto dal dark web) sul target e andiamo a creare il nostro dataset formato da informazioni, quali:

1. Persone
2. Organizzazioni
3. Siti Web
4. Indirizzi IPV4
5. Indirizzi crypto

6. Canali social

La mappatura risulterà quindi una serie di dati e i collegamenti che siamo in grado di recuperare su di essi:

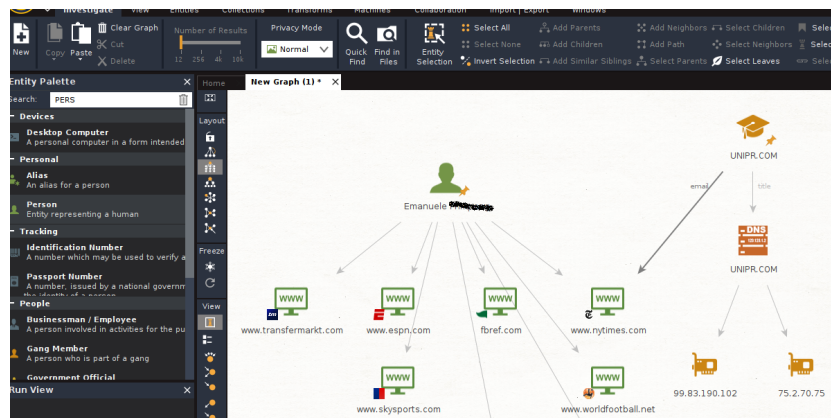


Figura 5.11: Mappatura di esempio, dati universitari ed email personale

Da sottolineare che questo tipo di investigazione può essere rivolto a qualsiasi individuo, organizzazione o professionista.

5.4 Analisi delle Informazioni dal Dark Web

Una volta terminato il mapping dei dati, recuperate tutte le informazioni comprese le loro origini, saremo in grado di seguire una serie di steps per mitigare i rischi di ulteriori compromissioni e saremo in grado di rafforzare la sicurezza della nostra organizzazione, per evitare ulteriori data breaches.

Verrà utilizzata la seconda macchina creata "SIEM E LOG MANAGEMENT" per eseguire analisi forensi, verificando come detto sopra i relativi log di sistema.

Utilizzeremo Splunk per tracciare gli eventi sulla macchina e possibili falle di sistema, e andando con questi dati ad alimentare l'input dei dati con informazioni locali.

CAPITOLO 5. CASO DI STUDIO: ESEMPIO CONCRETO

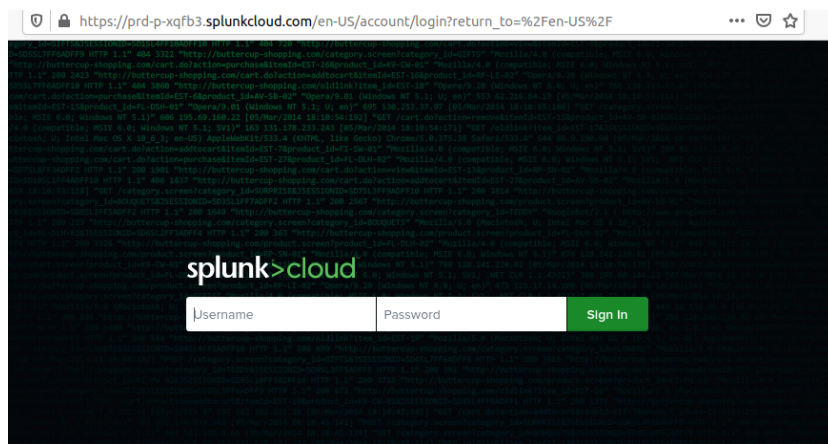


Figura 5.12: Landing page Splunk

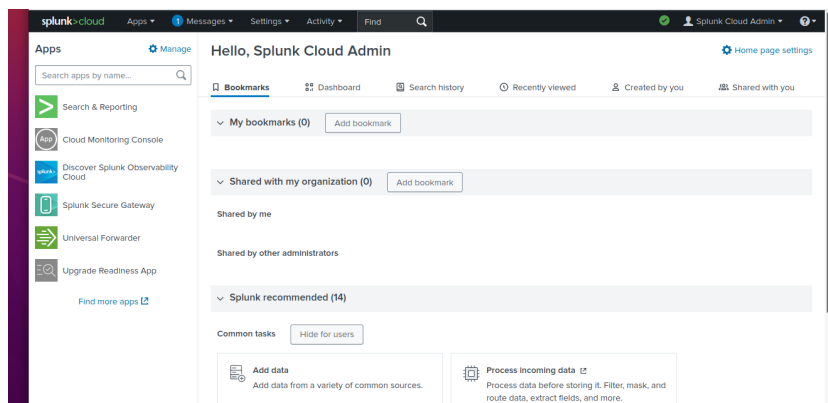


Figura 5.13: Homepage Splunk

Andremo ad eseguire la verifica di alcune attività in locale¹⁰.

Imposteremo i dati che vogliamo vengano analizzati (Local event log collection) e imposteremo la tipologia di dati in questo caso:

1. Applications
2. Security
3. System

Nella barra di ricerca andremo ad inserire il carattere speciale "*" con la quale andremo a recuperare ogni tipo di evento sul sistema. E in basso verrà visualizzato il risultato.

¹⁰Da ricordare che come ogni tool di monitoring è illegale eseguire scansioni su macchine di cui non si è proprietari o per le cui non si ha un'autorizzazione

CAPITOLO 5. CASO DI STUDIO: ESEMPIO CONCRETO

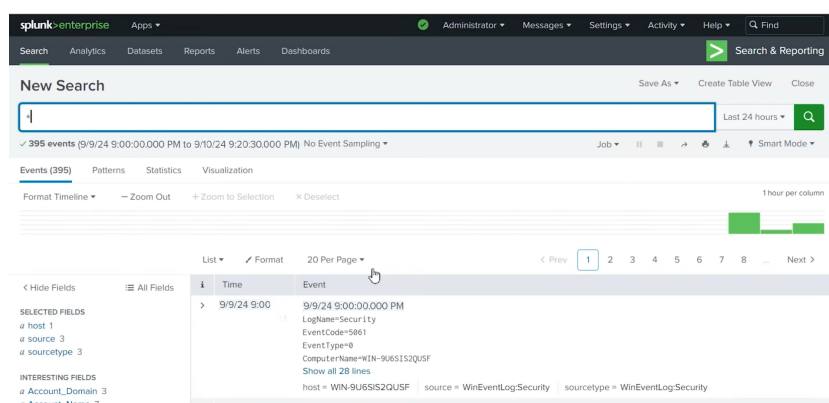


Figura 5.14: Ricerca generale di eventi

Sarà in oltre possibile fare ricerche specifiche per un host come in questo caso e osservare ogni azione/attività che viene eseguita. Filtrare per la Sorgente e eventualmente il codice dell'evento.

Per rendere la visualizzazione ancora più chiara e semplice, i dati raccolti potranno essere rappresentati all'interno di dashboards.

Il passo successivo dell'investigazione e della protezione dei dati avrà come obiettivo il contenimento e all'isolamento dei dati.

Identificando i sistemi compromessi o a rischio e isolando immediatamente questi asset dalla rete aziendale per prevenire ulteriori accessi non autorizzati. Con l'utilizzo di regole sul firewall e sistemi IDS/IPS¹¹ per bloccare le comunicazioni con gli IP o i domini associati ad attività sospette.

Un altro step utile sarà quello di richiedi un reset obbligatorio delle credenziali per tutti gli utenti coinvolti (in particolare se sono state rilevate credenziali compromesse). Invalidare tutti i token di sessione attivi e forza una ri-autenticazione su tutti i sistemi critici.

Una volta che il sistema sarà tornato in sicurezza, si passerà alla fase di verifica e test dei sistemi, utilizzando la VM di Penetration Testing, e con l'utilizzo del software Metasploit andremo a verificare che i sistemi siano aggiornati e patchatti con le ultime realese di sicurezza.

Collegandoci alla CLI di Metasploit avremo la possibilità di testare un gran numero di exploit sulle nostre macchine. Una volta che saremo avremo

¹¹Sistemi di rilevamento e prevenzioni delle intrusioni

Avvieremo il programma:

CAPITOLO 5. CASO DI STUDIO: ESEMPIO CONCRETO

(veniva usato questo specifico comando di exploit per ottenere accesso alle macchine delle vittime e poter eseguire gli attacchi):

```
USE AUXILIARY/SCANNER/SMB/SMB_MS17_010
```

Andremo poi a selezionare le opzioni e con **RHSOTS**, la macchina bersaglio. Una volta eseguito l'attacco però, riscontriamo il nostro sistema non è suscettibile a questa tipologia di attacco.

```
msf5 > use auxiliary/scanner/smb/smb_ms17_010
msf5 auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 10.0.2.15
RHOSTS => 10.0.2.15
msf5 auxiliary(scanner/smb/smb_ms17_010) > run
[*] 10.0.2.15:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf5 auxiliary(scanner/smb/smb_ms17_010) >
```

Figura 5.17: Vulnerabilità Non Rilevata

Nel caso in cui lo fosse stato, la risposta che avremmo ricevuto sarebbe stata la seguente:

```
msf6 auxiliary(scanner/smb/smb_ms17_010) > run
[*] 192.168.0.186:445 - Host is likely VULNERABLE to MS17-010! - Windows 10 Pro 14393 x64 (64-bit)
[*] 192.168.0.186:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_ms17_010) >
```

Figura 5.18: Vulnerabilità Rilevata

In questa cosa sarebbe poi possibile accedere alla macchina e proseguire l'attacco. Questa vulnerabilità sarebbe quindi da correggere al più presto.

Una volta verificate le varie vulnerabilità, l'obiettivo diventa quello di configura la macchina SIEM e Log Management per monitorare continuamente i log di accesso, informazioni dal dark web, gli eventi di sicurezza e le attività anomale (come questi attacchi) in tempo reale.

E quello di concentrarsi sull'educazione e sulla formazione dei dipendenti, che come abbiamo visto sono spesso l'anello più debole di un sistema di sicurezza aziendale.

Sarebbe poi indispensabile:

1. Condurre sessioni di formazione continua sulla consapevolezza della sicurezza informatica, inclusi phishing, social engineering, e gestione sicura delle informazioni.

2. Creare e distribuire SOPs (Standard Operating Procedures) per la risposta rapida agli incidenti e la gestione delle emergenze di sicurezza.
3. Validare le Contromisure Attraverso Test di Penetration regolari.
4. Organizzare simulazioni regolari di incidenti di sicurezza per verificare l'efficacia dei piani di risposta agli incidenti e la prontezza dei team.
5. Integrare le informazioni raccolte dal monitoraggio del dark web nel ciclo di sviluppo della sicurezza aziendale, migliorando continuamente le difese in base alle nuove minacce e ai trend osservati.

5.5 Risultati

Vediamo quindi come con il caso di studio appena proposto, il Dark Web venga utilizzata come risorsa di Open Source Intelligence per proteggere gli asset di un'organizzazione, tramite la configurazione e l'utilizzo di ambienti isolati (vulnbox) e strumenti di monitoraggio. Vediamo come la nostra startup tecnologica, operante nel campo del revenue management per compagnie aeree, abbia subito un attacco di phishing che ha portato alla compromissione delle credenziali dei dipendenti (e alla loro possibile vendita su forum del Dark Web) e come tramite gli strumenti a nostra disposizione sia stato possibile analizzare il problema, impostare correzioni o come sarebbe stato possibile prevenirlo.

L'ambiente è stato creato utilizzando una combinazione di macchine virtuali, che hanno simulato i sistemi dell'organizzazione. Queste macchine includevano:

1. Una macchina OSINT/Dark Web Monitoring per la raccolta di informazioni nel dark web.
2. Una macchina SIEM e Log Management per la gestione e l'analisi dei log di sistema.
3. Una macchina di Pentesting per simulare attacchi ed eseguire penetration testing.

L'isolamento di queste macchine ha garantito che le attività eseguite, avvenissero in un ambiente sicuro, minimizzando i rischi in caso di compromissione.

Per il monitoraggio e la raccolta di dati tramite OSINT, abbiamo analizzato come l'utilizzo di strumenti come TOR, Maltego, SpiderFoot e piattaforme di monitoraggio come DarkOwl Vision siano indispensabili per raccogliere

informazioni sensibili nel dark web riguardanti l'organizzazione. È stato rilevato un post su un forum di hacker in cui venivano vendute credenziali rubate dei dipendenti della startup, indicando una potenziale compromissione dei sistemi aziendali.

Abbiamo analizzato le informazioni raccolte dal dark web e tramite strumenti di monitoraggio del dark web sono stati analizzati e identificate possibili connessioni tra l'attore malevolo e l'organizzazione. Gli strumenti di gestione dei log, come Splunk, sono stati poi utilizzati per monitorare attività sospette, creare regole di correlazione e avvisi di sicurezza per migliorare la capacità di rilevamento e risposta dell'organizzazione.

E sono state introdotte contromisure per l'identificazione delle credenziali compromesse, sono state implementate contromisure come l'aggiornamento delle regole di sicurezza dei sistemi SIEM, l'applicazione di patch e il rafforzamento delle configurazioni di sicurezza. Sono stati avviati programmi di formazione continua per i dipendenti per aumentarne la consapevolezza sui rischi del dark web, del phishing e dell'ingegneria sociale. Sono stati implementati test regolari di penetration testing per verificare l'efficacia delle difese contro le minacce emergenti.

E si è evidenziata la necessità per il futuro di monitorare continuamente il dark web e le varie fonti OSINT per prevenire attacchi, di migliorare il piano di risposta agli incidenti, effettuando revisioni periodiche delle policy di sicurezza e continuare a rafforzare la resilienza dell'organizzazione contro minacce zero-day e minacce più sofisticate.

Capitolo 6

Considerazioni Etiche e Legali

Considerato quanto trattato finora, riconosceremo che navigare nel dark web con gli strumenti presentati, non è illegale di per se, ma dipende sempre dalle azioni che si compiono e dalle ricerche che si effettuano.

Sarà legale accedere al proprio account di posta elettronica o al proprio profilo social. Sarà invece illegale accedere a una rete aziendale o governativa senza autorizzazione o a una banca dati protetta da copyright.

Il pericolo proverrà sempre dal contatto che si andrà ad avere con il dark web, dove materiali illegali e immorali sono all'ordine del giorno.

Esistono infatti diverse leggi e norme che regolano l'uso di internet e che vietano, e sanzionano, determinate attività o contenuti, mirando a garantire la protezione dei dati personali, il contrasto al cybercrime, la protezione della proprietà intellettuale, e la prevenzione della diffusione di contenuti illeciti (come pornografia infantile, incitamento all'odio, terrorismo, e traffico di droga).

È fondamentale che le organizzazioni forniscano formazione continua in materia legale ed etica ai team che operano con l'OSINT e il dark web, implementino politiche interne allo scopo di definire chiaramente i limiti legali ed etici per l'utilizzo dell'intelligence. Queste policy devono riguardare l'uso di tutti gli strumenti dai software, ai dati fino alle fonti di informazioni.

6.1 Normative sulla Privacy

Vediamo di seguito alcuni dei principali regolamenti di sicurezza (come GDPR, CCPA, PCI-DSS) utili a condurre audit¹ per operare in conformità e in modo legale.

In particolare ne possiamo ritrovare di due tipologie, con una giurisdizione locale o nazionale. Con giurisdizione locale avremo:

Decreto Legislativo 70/2003 - Italia Questo decreto recepisce la Direttiva 2000/31/CE dell'UE, stabilendo disposizioni riguardanti il commercio elettronico, la responsabilità degli intermediari, e la tutela dei minori su internet. Viene impiegato contro fornitori di servizi, anche sul dark web, che non adempiono agli obblighi di segnalazione dei contenuti illegali o che facilitano la diffusione di contenuti illeciti.

Computer Fraud and Abuse Act (CFAA) - Stati Uniti È una legge federale degli Stati Uniti che disciplina l'accesso non autorizzato a computer e sistemi informatici in generale. Risulta in vigore dal 1986, è una legge utilizzata per perseguire reati di hacking, frodi informatiche, e attività di cracking. La si utilizza per giudicare e serve per perseguire chiunque, su qualsiasi livello del web (visibile o dark), acceda senza autorizzazione a un sistema informatico protetto.

Digital Economy Act - Regno Unito Questo regolamento del 2017 include misure per il controllo dei contenuti online, come la pornografia e materiale di tipo estremista o terroristico, si concentra anche sul rafforzamento delle leggi contro la pirateria digitale. Ne è soggetto chiunque operi nel web, compreso il dark web, e renda disponibili contenuti che infrangono il Digital Economy Act, l'offensore potrà essere soggetto a multe e ad altre sanzioni legali.

Cybersecurity Law - Cina La legge sulla sicurezza informatica cinese impone controlli rigorosi sull'accesso a Internet e sull'utilizzo di dati all'interno del paese. È stata sviluppata per proteggere la sovranità digitale del paese, garantire la sicurezza nazionale e mantenere la stabilità sociale. Ne è soggetta qualsiasi attività online, sia sul web visibile che nel deep o dark web, è soggetta a stretti controlli da parte delle autorità cinesi, comprese le

¹è una valutazione indipendente volta a ottenere prove, relativamente a un determinato oggetto, e giudicarle e con obiettività, al fine di stabilire in quale misura i criteri prefissati siano stati soddisfatti o meno

attività che potrebbero essere considerate sovversive o dannose per l'ordine pubblico.

É poi importante sottolineare come diversi paesi ad oggi abbiano adottato leggi che vietano il traffico di stupefacenti, la vendita di armi, la tratta di esseri umani, il terrorismo e la diffusione di materiali illeciti. In aggiunta a questo sono state predisposte una serie di autorità, come l'FBI negli Stati Uniti, l'Europol nell'UE (Unione Europea), insieme ad altre agenzie di polizia, per collaborare e monitorare il web ed in particolare il dark web e intraprendere azioni contro tali attività



Figura 6.1: La legge e la cybersecurity

6.1.1 Regolamentazioni Internazionali

La Convenzione di Budapest è il quadro legale internazionale per affrontare i crimini informatici a livello globale, con un impatto esteso in tutto il mondo grazie all'adesione di molte nazioni. Il GDPR come la convenzione di Budapest ha un impatto globale grazie alla sua applicabilità extraterritoriale, influenzando la conformità alla protezione dei dati tutte le aziende che trattano dati di cittadini dell'UE.

La Convenzione di Budapest (Convention on Cybercrime) - Consiglio d'Europa La Convenzione di Budapest, aperta alla firma il 23 novembre 2001 a Budapest, Ungheria, ed entrata in vigore il 1^o luglio 2004, è il primo trattato internazionale che mira a combattere il crimine informatico, è stata firmata da numerosi paesi in tutto il mondo, la maggior parte dei membri del Consiglio d'Europa, gli Stati Uniti, il Canada, il Giappone e molti

altri. Stabilisce norme minime per la legislazione nazionale relativa ai crimini informatici e promuove la cooperazione internazionale per indagini e azioni legali contro il cybercrime. Copre una vasta gamma di reati informatici, tra cui l'accesso non autorizzato, l'intercettazione illecita, la manipolazione di dati, e la pornografia infantile.

Regolamento Generale sulla Protezione dei Dati (GDPR) - Unione Europea Anche se è principalmente una normativa dell'Unione Europea, il GDPR² ha un impatto internazionale. È applicabile a tutte le aziende, organizzazioni e entità, indipendentemente dalla loro ubicazione geografica, se trattano i dati personali di cittadini o residenti dell'UE. Impone severi requisiti per la protezione dei dati personali e per la privacy, influenzando globalmente il modo in cui le organizzazioni trattano i dati degli utenti. La sua applicabilità extraterritoriale ha portato molte aziende al di fuori dell'UE ad adattare le loro pratiche per essere conformi alla normativa.

Altri Accordi Internazionali di Cooperazione nel Contrastare il Cybercrime Oltre alla Convenzione di Budapest, ci sono altri accordi e protocolli internazionali che promuovono la cooperazione tra paesi per combattere il cybercrime. Questi possono includere accordi bilaterali o multilaterali tra paesi, per facilitare la condivisione di informazioni, l'estradizione di cybercriminali, e altre misure di sicurezza cibernetica. Questi accordi sono solitamente basati sul diritto internazionale e promuovono una risposta coordinata alle minacce informatiche, considerando che il cybercrime spesso coinvolge più giurisdizioni.

6.2 Limiti Legali e Implicazioni Etiche

Sebbene l'OSINT utilizzi dati cosiddetti "aperti" o disponibili pubblicamente, c'è un dibattito etico su quanto sia giusto raccogliere informazioni personali (tecnicamente disponibili) senza il consenso dell'individuo. In quanto l'aggregazione massiccia di dati, la creazione di profili, o il tracciamento di comportamenti possono essere percepiti come una violazione della privacy.

Le profilazioni automatizzate attraverso strumenti OSINT possono introdurre bias (pregiudizio o allerta), con implicazioni negative per la privacy e la sicurezza individuale. Ad esempio, una persona può essere etichettata erroneamente come una minaccia o un sospettato basato su dati incompleti o

²Il GDPR è stato adottato il 27 aprile 2016, ed è entrato in vigore il 25 maggio 2018

errati. Gli strumenti di monitoraggio del dark web e dell'OSINT, sbiadiscono la sottile linea tra la protezione proattiva e la sorveglianza ingiustificata, in quanto possono essere usati sia per scopi legittimi (come la sicurezza e la protezione della privacy) sia per scopi malevoli (come lo stalking o la manipolazione dei dati).

Le organizzazioni che utilizzano tecniche OSINT e monitoraggio del dark web devono poi operare con trasparenza, informando le persone i cui dati potrebbero essere raccolti e analizzati. E in casi particolari ottenere il consenso per la gestione delle informazioni. Gli analisti di cybersecurity e le aziende devono invece rispettare le best practices etiche e normative quando monitorano dati pubblici e il dark web. Ad esempio, quando si conducono ricerche su hacker particolarmente pericolosi, è necessario considerare i rischi di escalation o di danni collaterali.

Conclusione

L'integrazione dell'Open Source Intelligence con le risorse presenti nel Dark Web hanno offerto un approccio potente e innovativo alla protezione degli asset di un'organizzazione in un panorama di cyber threat sempre più complesso. Il caso studio proposto ha dimostrato come l'uso combinato di strumenti di monitoraggio e analisi, ambienti isolati, e macchine dedicate, possa fornire un quadro completo per identificare, analizzare e mitigare le minacce.

Il Dark Web, con le sue caratteristiche di anonimato e difficile accessibilità, rappresenta una fonte unica di informazioni critiche per gli analisti di cybersecurity. Esso ha infatti permesso di accedere a dati e informazioni non indicizzati, di rivelare attività criminali, tentativi di vendita di credenziali compromesse, e altre minacce emergenti. In combinazione con le tecniche OSINT, che facendo uso di informazioni pubbliche, hanno permesso di ottenere un quadro chiaro di intelligence in grado di ampliare significativamente la capacità di individuazione delle minacce, comprendere le loro origini, i loro vettori di attacco, e quindi di reagire in modo tempestivo ed efficace

Il caso di studio ha dimostrato l'importanza dell'utilizzo del Dark Web come fonte di informazioni OSINT. Si è analizzato come un'organizzazione possa utilizzare determinate informazioni per migliorare le proprie abilità di difesa. L'implementazione di ambienti isolati, il monitoraggio continuo del Dark Web e l'adozione di contromisure appropriate sono stati elementi cruciali per garantire la sicurezza informatica e la protezione dei dati sensibili.

È stato analizzato come determinati strumenti siano fondamentali per il monitoraggio del Dark Web, per la creazione di regole di correlazione e creazione di "allarmi" di sicurezza, migliorando la capacità di risposta alle minacce. Inoltre, è stata evidenziata l'importanza di un'adeguata formazione per i dipendenti e di una continua revisione delle policy di sicurezza in previsione di possibili attacchi.

L'analisi combinata delle risorse è quindi fondamentale per la cybersecurity moderna. Mentre il Dark Web rappresenta un ambiente ricco di dati

non convenzionali ma di grande valore, l'OSINT offre una base metodologica solida per raccogliere, analizzare e sfruttare questi dati. Tuttavia, operare in questi contesti comporta sfide significative, oltre a considerazioni etiche e legali che non devono essere trascurate.

In conclusione, l'integrazione tra questi due potenti strumenti rappresenta una strategia efficace e necessaria per le organizzazioni che desiderano rimanere resilienti contro le minacce. L'adozione di un approccio proattivo al monitoraggio dei cyber threat e alla risposta agli incidenti, unito a un costante aggiornamento delle tecniche e delle tecnologie, è essenziale per mitigare i rischi associati alle minacce zero-day e ad attacchi sempre più sofisticati. In un contesto digitale in continua evoluzione, la capacità di adattarsi rapidamente e di utilizzare tutte le risorse disponibili, sarà sempre più cruciale per la sicurezza e la protezione delle organizzazioni.

Bibliografia

- [1] Mattia Argiolas. Dark web monitoring: 7 tool per scoprire se i tuoi dati sono al sicuro. *news-informatica*, 2024.
- [2] Ludo Block. The long history of osint. *Journal of Intelligence History*, 23(2):95–109, 2024.
- [3] Ryan Ehney and Jack D. Shorter. Deep web, dark web, invisible web and the post isis world. *Issues in Information Systems*, 17:36–41, 2016.
- [4] Marshall Gunnell. Dark web. *Techopedia*, 2023.
- [5] Omkar Hiremath. Protecting your organization with open-source intelligence (osint). *Software secured*, 2024.
- [6] Kody Kinzie. What is osint? *Varonis*, 2022.
- [7] Jin R. Lee, Ariel L. Roddy, and Mikaela A. Wallin. The dark web as a platform for crime: An exploration of illicit drug, firearm, csam, and cybercrime markets. *The Palgrave Handbook of International Cybercrime and Cyberdeviance*, pages 91–116, 2020.
- [8] Gregg Lindemulder and Amber Forrest. Che cos'è l'open-source intelligence (osint)? *IBM*, 2024.
- [9] Ricardo Nardini. Il mercato nero del dark web: i prodotti più venduti, i prezzi e i miti da sfatare. *CyberSecurity360*, 2023.
- [10] Ameer Owda. Top 10 deep web and dark web forums. *Bonus: Daily Dark Web*, 2024.
- [11] Shannon Ragan. 5 tips for osint ont the the dark web. *AUTENTIC8*, 2023.